



Network Security (IE3122)
3rd Year, 1st Semester

Assignment

**Northbridge Savings & Finance Network
Security Upgrade**

Submitted to
Sri Lanka Institute of Information Technology

IT24100139	Pinthu D.I.U.
IT24101169	Weligampitiya S.A.S.D.
IT24102358	Silva D.P.L.T.D.
IT24102328	Wickrama Edirisooriya A.A.G.

In partial fulfillment of the requirements for the
Bachelor of Science Special Honors Degree in Information Technology

16 September 2026

Table of Contents

Table of Contents.....	1
1. Individual Threat Modeling	3
Member 1 - IT24100139 - Pinthu D.I.U.	3
Member 2 - IT24101169 - Weligampitiya S.A.S.D.	6
Member 3 - IT24102358 - Silva D.P.L.T.D.	7
Member 4 - IT24102328 - Wickrama Edirisooriya A.A.G.	11
2. Combining Into a Layered Security Plan	12
2.1 Master List of Proposed Controls	12
2.2 Control-to-Threat/Attack Mapping	14
2.3 Function × Category Dual-Axis Table.....	14
2.4 Control Minimization Write-up	14
3. Mandatory Technology Components.....	15
3.1 VPN Solution	15
3.2 AAA Solution	16
3.3 Secure Network Architecture.....	16
3.4 IDS/IPS Solution	17
4. Individual Network Hardening Configurations	18
Member 1 - IT24100139 - Pinthu D.I.U.	18
Member 2 - IT24101169 - Weligampitiya S.A.S.D.	28
Configuration 1 (Plan-linked): Port Security.....	28
Member 3 - IT24102358 – Silva D.P.L.T.D.	35
Configuration 1 (Plan-linked): AAA Centralized Authentication with RADIUS and SSH-only Management	35
Configuration 2: Extended ACL Zone Enforcement Between the Guest, Branch and Core Banking Zones	40
Member 4 - IT24102328 – Wickrama Edirisooriya A.A.G.	46
Configuration 01(Plan-Linked): Dynamic ARP Inspection (DAI)	46
Configuration 02(Free Choice): Zone-Based Policy Firewall (ZPF)	53
5. Appendices A-D.....	64
Individual technology proposals	64
Member 1 - IT24100139 - Pinthu D.I.U.	64
VPN Proposal	64
AAA Proposal	65
Secure Network Architecture Proposal.....	65

IDS/IPS Proposal.....	66
Member 2 – IT24101169 – Weligampitiya S.A.S.D.....	67
VPN Solution - Secure Remote Access	67
AAA Solution - Centralized Authentication	67
Secure Network Architecture - Multiple Firewalls, Defined Zones	68
IDS/IPS Solution	68
Member 3 - IT24102358 - Silva D.P.L.T.D.....	69
VPN Solution - Secure Remote Access	69
AAA Solution - Centralized Authentication	69
Secure Network Architecture - Multiple Firewalls, Defined Zones	70
IDS/IPS Solution	71
Member 4 - IT24102328 – Wickrama Edirisooriya A.A.G.	72
VPN solution for secure remote access.....	72
An AAA solution for centralized authentication.....	72
A secure network architecture incorporating multiple firewalls and defined zones.....	73
An IDS/IPS solution	73

Note: this field updates automatically in Microsoft Word. If page numbers don't appear immediately, select the whole document (Ctrl+A) and press F9, or right-click the table and choose “Update Field”.

1. Individual Threat Modeling

Member 1 - IT24100139 - Pinthu D.I.U.

Risk Rating Method

Risk Score = Likelihood x Impact. This is a chosen assessment method for the report; the assignment brief does not prescribe a specific numeric matrix

Score	Rating
1-4	Low
5-9	Medium
10-16	High
17-25	Critical

Threat 1 - Credential compromise through social engineering and weak password practices.

Element	Member 1 Content
Asset	Employee credentials, internal email accounts, VPN accounts, access to the core banking system, customer financial and personal information, and administrative credentials.
Vulnerability	There was no security awareness training, no use of multi-factor authentication, password reuse being practiced by the branch staff, passwords being shared, no centralised authentication system, a shared VPN account, and no consistent procedure for identifying and reporting social-engineering attacks.
Threat	An outside attacker obtains a legitimate employee's password by using social engineering techniques such as phishing, spear-phishing, vishing, or by impersonating an IT help desk agent.
Exploit	The attacker takes advantage of people's trust, their lack of awareness training, the practice of reusing or sharing passwords, and the fact that multi-factor authentication is not in place. For instance, the attacker can pretend to be IT support and convince a staff member at a branch to give out a password; the reused credentials could then be used on a number of different services.
Attack	1) Carry out reconnaissance to identify a Northbridge employee. 2) Use social engineering by contacting the employee while pretending to be from the IT Helpdesk or by showing them a fake login page. 3) Steal the password. 4) Carry out unauthorized authentication by using the credentials to log into the VPN, email, or other internal services. 5) Obtain higher privileges or gain access to other systems by exploiting the reuse of the password. 6) Commit data theft, carry out fraud, or deploy malware using the compromised identity as the starting point.
Impact	With regard to confidentiality, customer and employee information could be made available. As for integrity, financial or customer records might be altered depending on

	the permissions granted. Regarding availability, the compromised identity could be used to carry out malware or ransomware activities. In the financial area, unauthorized transactions or fraud could take place. On the regulatory front, the exposure of financial or customer data might result in compliance consequences. As for reputation, customer confidence could be harmed.
Likelihood	5 - Very high. An attempt at social engineering has already taken place in Northbridge, and password reuse or sharing, the absence of multi-factor authentication, and the lack of awareness training are still existing.
Impact Rating	5 - Severe. It is possible that a successful compromise could come to light and reveal information about banking systems and customers' financial details.
Risk Rating	5 x 5 = 25. This is important.
Northbridge-Specific Justification	It isn't just a matter of theory since a person has already taken on the identity of the IT Helpdesk and asked for an employee's password. The failure to have multi-factor authentication, centralized authentication, security awareness training, and strong password practices increases the chance that stolen credentials will be used successfully.

The controls available for threat 1

- Using centralised AAA and providing individual user accounts reduces the number of unmanaged local identities and enhances accountability.
- MFA is required in the case of access to the VPN, to privileged access, to administration, and for access to sensitive applications.
- The training should include content on phishing, vishing, fake IT support, password requests, and the procedures for reporting incidents.
- Apply a strong password and credential policy by banning the sharing of passwords, the reuse of organizational passwords, and shared remote-access accounts.
- Centralized logging and account monitoring help find unusual authentication behavior.

Threat 2 - Third-Party Payment Integration Compromise Leading to Unauthorized Access/Data Breach

Element	Member 1 Content
Asset	Customer financial data; personal identifiable information of customers; payment transactions; the core banking systems; the payment API and integration servers; the API credentials, tokens, and certificates; the online banking services; and Northbridge's reputation.
Vulnerability	There is no security assessment procedure provided by any vendor; there is no effective network segmentation; no dedicated firewall is in place; no intrusion detection system or intrusion prevention system is available; there is no centralised logging; the network has a flat structure; there is an upcoming third-party integration; and the overall security governance is weak.
Threat	A threat involves an attacker gaining access to one of Northbridge's payment-processing partners or acquiring the credentials related to the integration, and then taking advantage of the trusted third-party relationship to launch an attack against Northbridge. This is an example of a third-party/supply-chain security threat.

Exploit	The attacker could take advantage of excessive trust between networks, poorly restricted access by partners, compromised API credentials, insecure integration accounts, weak authentication, the absence of network segmentation, and inadequate monitoring. For instance, a compromised integration account or API credential might be used to send malicious requests to Northbridge.
Attack	1) The payment provider has been compromised. 2) The attacker acquires the integration/API credentials. 3) The attacker then connects via the trusted third-party channel. 4) Northbridge regards the traffic as trusted. 5) The attacker gains access to the payment-integration infrastructure. 6) Because of poor segmentation, the attacker is able to make attempts to reach other internal systems. 7) Customer data or information about transactions is accessed. 8) Data exfiltration or unauthorized transactions take place.
Impact	Regarding confidentiality, customers' financial and personal data could be stolen. As for integrity, payment transactions might be altered or falsely created. Regarding availability, the payment integration or the systems linked to it could be disrupted. In the financial area, fraudulent transactions and the costs associated with incident response might take place. On the regulatory front, a breach involving customers' or financial data could result in compliance consequences. As for reputation, both customers and regulators might lose trust.
Likelihood	Likelihood4 - High. Although the integrations have not yet been put into place, Northbridge at the moment does not have a formal vendor-security assessment procedure and has poor segmentation and monitoring.
Impact Rating	Impact Rating: 5 — Severe; a successful compromise could have an effect on financial transactions and on sensitive customer information.
Risk Rating	Risk Rating $4 \times 5 = 20$. CRITICAL.
Northbridge-Specific Justification	The reason specific to Northbridge is that the payment processors will soon be regarded as external dependencies that can be trusted. At present, Northbridge does not have a formal procedure for assessing third parties, and its network is not adequately segmented nor does it have IDS/IPS systems or centralised logging. If a partner were to be compromised it could become a major route into the organization.

The controls available for threat 2

- Establish a third-party payment security area to separate the payment integrations from the other Northbridge networks.
- The firewall/ACL rules of the least-privilege type permit only the necessary source, destination, protocol, and port.
- The Third-Party Security Assessment Programme should involve evaluating the vendors before they are integrated and then at regular intervals after that.
- The IDS/IPS should check the traffic from the partner and from the Internet for any suspicious behaviour.
- The Central Logging/SIEM system should record events such as API authentication, firewall activities, failed connections, unusual transactions, and security alerts.

Member 2 - IT24101169 - Weligampitiya S.A.S.D.

Threat 1 - Ransomware spread via the unsegmented network.

Asset	Core banking application and customer database (head office data centre).
Vulnerability	No network segmentation - head office systems, branch systems, guest Wi-Fi, and PoS equipment share the same flat network space.
Threat	Ransomware, consistent with the regional industry association's report of rising ransomware incidents against mid-sized financial firms.
Exploit	Attackers compromise a single branch workstation (e.g. via phishing email or an unpatched application - branch systems are known to run outdated software with no formal patch management).
Attack	Because there is no segmentation and no IDS/IPS to detect lateral movement, the ransomware spreads from the branch workstation across the flat network toward head office systems, including the core banking database.
Impact	Encryption/unavailability of the core banking database and online banking portal, halting operations across all 6 branches and head office; potential customer data exposure.
Risk rating	High - likelihood is elevated by the documented sector-wide trend and Northbridge's own unpatched systems; impact is severe given the assets are Northbridge's most critical (customer financial data) and the bank explicitly depends on continuous branch-to-head-office connectivity.

Threat 2: Unauthorized remote access via the shared VPN account.

Asset	Internal systems are accessible via remote access, including core banking systems reachable by IT support contractors.
Vulnerability	Single shared, non-individual VPN account used interchangeably by remote staff and two external IT contractors, with no MFA and no individual accountability.
Threat	Credential theft/misuse - either an external contractor's device is compromised, or the shared credential leaks (made more likely given password reuse/sharing is common among staff).
Exploit	Because the VPN account is shared, a leaked or phished password lets an attacker connect as if they were a legitimate contractor — no MFA to stop it.
Attack	Attacker authenticates over VPN using the shared credential and moves onto the internal network as a “trusted” remote user, with no logging to distinguish them from real staff/contractors.
Impact	Undetected unauthorized access to internal systems; because there is no centralized logging, the bank may not realize the account was misused until damage (e.g. data exfiltration) is visible.
Risk rating	High - this closely mirrors the actual attempted social-engineering incident in the scenario (attacker tries to get credentials), and the complete lack of MFA/individual accountability means there is no second line of defense if it succeeds.

Member 3 - IT24102358 - Silva D.P.L.T.D.

Threat 1 - Compromise of personal/BYOD devices leading to unauthorized access to internal banking systems.

Asset	The remote access path itself, the staff credentials and internal email accessed from personal devices, and the core banking database containing customer financial and personal data at the head office data center.
Vulnerability	Northbridge allows people to work from home and to use their own personal machines and phones for work but there are no guidelines or rules for these occasions. Those devices are not covered by any patch management process; there is no multi-factor authentication anywhere in the organization and remote access is provided through a single shared VPN account with no individual accountability.
Threat	A commodity credential-stealing malware compromises an unmanaged personal/BYOD device, operated by a financially motivated attacker or an initial access broker who resells the stolen credential.
Exploit	An unpatched personal laptop used for work is infected by ordinary means outside the visibility of Northbridge (malicious download or an attachment opened in a personal mailbox). The malware collects saved credentials from browsers and VPN clients, including the shared password for the VPN account. The password itself is a complete credential that can be used immediately, so there is no MFA.
Attack	The attacker authenticates the VPN using the stolen shared credential from their own infrastructure. Because there is no centralized logging and the account is shared, the session is indistinguishable from a legitimate contractors. There is no segmentation in the network, so the attacker is adjacent to head office systems and the core banking environment and uses the harvested passwords against local device and application accounts. This is made easier because password reuse and sharing is common among staff.
Impact	Exposure of customer financial and personal data, the asset with the most direct regulatory and financial consequences for

	Northbridge; possibility of alteration of records once inside the core banking application; and, if ransomware is staged from the same foothold, loss of availability with an unknown recovery time, as backups exist but have never been tested for successful restoration. That integration going live will hurt regulatory standing and customer confidence and lengthen the exposure to the two payment processing partners.
Risk rating	Critical – likelihood is very high as there is no hypothetical element here where every precondition already exists: BYOD has no rules, no patching, the VPN account is shared and no MFA to fail, credential-stealing malware is commodity-grade so Northbridge doesn't need to be individually targeted. The impact is very high because there is nothing to stop the chain between the infected home laptop and the customer database, the lack of segmentation removes the only internal boundary, and the lack of centralized logging means that even after the fact, the scope of a breach could not be established. With per user VPN accounts and MFA at a bank this chain would stop at the first step. Which is why the rating is about the missing controls, not the malware itself.

Threat 2 - Unauthorized access to core banking systems through compromised branch network equipment.

Asset	Continuous branch-to-head-office connectivity, which the bank depends on to keep core banking services available throughout the day, together with the branch networking equipment itself and, through that path, the core banking application and customer database.
Vulnerability	Physical access to networking equipment in branch back offices is uncontrolled, with cabinets found unlocked in at least two locations during a recent informal walkthrough. Visitor sign-ins are inconsistently enforced, and no site has security signage, badge checking or camera coverage at entry points. There is no network segmentation, no centralized authentication system (every device keeps its own local accounts, and password reuse and sharing is common at branch level), no IDS/IPS anywhere, and no centralized logging or audit trail.

Threat	An opportunistic intruder masquerading as a customer, courier or IT contractor or a malicious insider already in possession of legitimate branch access attaching a rogue device to the branch access network or gaining administrative access to branch switching equipment.
Exploit	The attacker walks into the branch back office on a routine pretext and opens an unlocked cabinet. No port security . No 802 . 1X . A small implant is connected to a live access port . The switch forwards for it immediately . No DHCP snooping . It gets a valid address on the branch network . The implant performs ARP cache poisoning on the same flat segment as branch workstations, which is successful because there is no Dynamic ARP Inspection to drop the forged bindings. Alternatively the attacker uses the console port with a reused or shared local device password which is plausible given the lack of any centralized authentication system.
Attack	The implant is positioned on path between branch workstations and their gateway, captures staff credentials in transit, and can maintain a persistent remote foothold. Armed with valid credentials and no segmentation, the attacker pivots from the branch segment to head office systems and the core banking environment, via branch hosts known to run outdated software. This mirrors the pattern reported by the regional industry association where incidents started with a single compromised branch workstation and quickly propagated across an unsegmented network. There is no IDS/IPS and no centralized logging so nothing trips an alarm.
Impact	Bulk theft of staff credentials, and through them, unauthorized access to customer data Alteration of traffic and logs from the on-path position Loss of branch-to-head-office connectivity, if the foothold is used to drop ransomware, bringing core banking to a halt across the affected sites. Without camera coverage, a reliable visitor record and centralized logs, Northbridge could not determine who put the device there, when or what was taken, forcing a worstcase assumption in any regulatory notification.
Risk rating	High - likelihood is high but not very high because the attack necessitates a short presence in the branch, and this is a realistic

	constraint. In all other respects, the barriers have already been eliminated through observation and not just hypothesis: the cabinets are unlocked, sign-ins are inconsistent, and there is nothing at all in the way of signage or video surveillance to deter the action. The impact is very high because the branch sub-component is not segregated from the rest of the core banking system, meaning that a branch compromise is an attack on the core banking system with added steps, while detection is impossible, leading to indefinite dwell time. It is notable that historically Northbridge has invested solely in physical security, including vaults, alarm systems and branch cameras, in order to protect its cash, but the network cabinet in the same building enjoys none of this protection and connects to everything.
--	--

Member 4 - IT24102328 - Wickrama Edirisooriya A.A.G.

Threat 1 - Data breach through outdated/unpatched systems.

Asset	Core banking application, customer database and branch systems running outdated software.
Vulnerability	No formal patch management process; several branch systems run outdated applications and OS versions.
Threat	Exploitation of known vulnerabilities in unpatched software (unpatched windows, outdated web server)
Exploit	Attacker scans for known CVEs on unpatched branch systems, uses a public exploit (EternalBlue, unpatched RPD) to gain access.
Attack	Attacker gains initial foothold on an unpatched branch workstation, escalates privileges, moves laterally to core banking systems.
Impact	Data breach of customer financial/personal data; regulatory penalties; reputational damage; potential ransomware deployment.
Risk rating	High – likelihood is elevated because patch management is absent and outdated systems are confirmed; impact is severe given the asset is Northbridge's most critical data and regulatory standing is at stake.

Threat 2 - Unauthorized physical access to critical IT infrastructure.

Asset	Head office server room, branch network cabinets, networking equipment, core banking servers.
Vulnerability	Server room secured by a single shared key (no audit trail); no camera coverage; branch cabinets left unlocked; visitor sign-ins inconsistently enforced; no security signage.
Threat	Malicious insider or opportunistic intruder seeking physical access to critical infrastructure.
Exploit	Attacker uses the shared key (or finds an unlocked branch cabinet) to physically access servers/switches; no camera or badge system to deter or record them.
Attack	Attacker connects a rogue device (USB, laptop, malicious switch) directly to networking equipment or servers, bypassing all network perimeter controls.
Impact	Direct compromise of core banking systems; data theft; malware installation; complete bypass of logical security controls; no forensic evidence due to lack of logging/ cameras.
Risk rating	High – likelihood is elevated because physical controls are weak and undocumented (shared key, unlocked cabinets); impact is severe because physical access bypasses all network security controls.

2. Combining Into a Layered Security Plan

This section combines all eight individually modeled threats (Section 1) into one integrated, reconciled plan. Overlapping proposals from different members were merged into single controls where they addressed the same underlying gap.

2.1 Master List of Proposed Controls

The controls below were synthesised from all eight threats in Section 1 and all sixteen individual technology proposals in Appendices A–D. Where two members independently proposed the same underlying control (see 2.4), they were merged into a single numbered entry rather than counted twice.

#	Control Name	Short Description
1	Centralized AAA — Aruba ClearPass Policy Manager (RADIUS + TACACS+) + ClearPass OnGuard endpoint posture assessment, AD-integrated, with MFA	Replaces per-device/per-application local accounts and the shared VPN account with individually attributable, centrally managed authentication; OnGuard denies or quarantines non-compliant (unpatched, missing AV) endpoints at the point of network access.
2	VPN — Palo Alto GlobalProtect SSL/IPSec with per-user MFA and HIP (Host Information Profile) endpoint compliance checks	Replaces the single shared VPN account with individual, auditable sessions, and verifies OS patch level and antivirus status before a remote or personal (BYOD) device is allowed to tunnel in.
3	Zoned, tiered network architecture (Palo Alto perimeter + internal + dedicated industrial firewall for PoS/OT; zones for Internet, DMZ, core banking, database, management, guest Wi-Fi, PoS/OT, per-branch VLAN, partner, and VPN users)	Replaces the current flat network with defined security zones — including a purpose-built industrial firewall isolating point-of-service equipment — so a compromise in one zone or branch cannot freely reach another.
4	In-line IPS + flow-based anomaly detection (Palo Alto Threat Prevention IPS at firewall choke points + Cisco Stealthwatch using NetFlow/IPFIX)	Actively blocks known-signature attacks in-line, and separately detects behavioral anomalies (e.g. internal scanning, lateral movement) even when no signature exists, closing the current total visibility gap.

5	Extended ACLs / zone-based policy firewall enforcing least-privilege between zones	Encodes specific allow/deny rules for traffic crossing zone boundaries (e.g. guest → core banking denied; branch → core banking limited to required ports only).
6	Port Security on branch access-layer switches	Restricts each access port to one authorized MAC address and shuts the port down on violation, preventing rogue devices being plugged into branch access ports.
7	DHCP Snooping	Prevents rogue DHCP servers on the network from issuing malicious IP configuration to clients.
8	Dynamic ARP Inspection (DAI)	Prevents ARP cache poisoning / on-path attacks on the flat branch segment by validating ARP packets against the DHCP snooping binding table.
9	Third-party vendor security assessment programme	Formal process to assess payment-processing partners' security posture before and after integration, addressing the current lack of any vendor assessment procedure.
10	Security awareness training programme	Trains staff to recognise phishing, vishing, and fake-IT-support social-engineering attempts, addressing the gap exposed by the recent incident.
11	Strong password / credential policy	Formally bans password sharing and reuse across branch staff, complementing the technical AAA/MFA control with an administrative policy.
12	Centralized logging / SIEM	Aggregates authentication, firewall, IPS, and flow-analytics events so anomalous behaviour can be detected and investigated, addressing the current lack

		of any centralized audit trail or forensic capability.
13	Physical access control and monitoring (RFID badge system + CCTV + audit logs)	Replaces the single shared server-room key and unlocked branch cabinets with auditable, individually attributable physical access, visual deterrence, and evidence for investigation.

2.2 Control-to-Threat/Attack Mapping

T1–T8 refer to the eight threats in Section 1, in the order they appear there (T1–T2: Member 1; T3–T4: Member 2; T5–T6: Member 3; T7–T8: Member 4).

Control #	Threats/Attacks Addressed
1	T1, T4, T5, T6, T7
2	T4, T5, T7
3	T2, T3, T6
4	T2, T3, T6, T8
5	T2, T3, T6
6	T3, T6
7	T6
8	T6
9	T2
10	T1
11	T1, T6
12	T1, T2, T4, T6, T8
13	T8

2.3 Function × Category Dual-Axis Table

Function \ Category	Administrative	Technical	Physical
Preventive	9, 10, 11	1, 2, 3, 5, 6, 7, 8	13
Detective		1, 4, 6, 12	13
Deterrent	10		13
Corrective			
Recovery		12	
Compensating		3	

2.4 Control Minimization Write-up

The group deliberately reduced the control count by merging proposals that independent members had converged on for the same underlying visibility gap. Member 3's IDS/IPS proposal (Appendix C) paired FortiGuard IPS with a secondary passive Suricata sensor on a SPAN port specifically to get always-on, non-blocking visibility as a safety net alongside the in-line IPS. Member 4's IDS/IPS proposal (Appendix D) paired Palo Alto Threat Prevention IPS with Cisco Stealthwatch flow analytics for the same underlying reason — catching activity a signature-based IPS alone would miss. Rather than deploy both a passive Suricata sensor and Stealthwatch side by side, the group folded this into a single Control 4, since Stealthwatch's flow-based anomaly detection already delivers the always-on visibility function Member 3's passive sensor was intended to provide, without running two separate

monitoring products. This is reflected in Control 4 addressing four threats (T2, T3, T6, T8) through one integrated control rather than two overlapping tools.

A narrower alternative the group considered and explicitly rejected was deploying a dedicated patch-management platform (e.g. WSUS plus a vulnerability scanner) as its own numbered control to address Threat 7 (unpatched systems). Instead, the group relies on the endpoint posture checks already built into Controls 1 and 2 — ClearPass OnGuard (local/branch network join) and GlobalProtect HIP (remote VPN join) — both of which already verify OS patch level and quarantine or deny non-compliant devices at the point of connection. The group is honest that this is a narrower form of protection than a full continuous asset-management platform, since it only checks a device's patch state at the moment it connects or reconnects, not continuously while already on the network; it was judged a proportionate trade-off given Northbridge's size and its newly formed, likely small security team, rather than adding and maintaining a fourth platform.

The group did knowingly accept redundancy in one place: Controls 1 and 2 both perform endpoint-posture/compliance checking (ClearPass OnGuard and GlobalProtect HIP respectively), which is conceptually the same function performed twice. This was kept deliberately rather than merged, because the two controls gate two different access paths — a local branch network connection versus a remote VPN tunnel — and a device could bypass compliance checking entirely by using whichever path lacked it if only one control performed the check.

The group also kept the zoned network architecture (Control 3) and the extended ACLs/zone-based firewall rules (Control 5) as two distinct controls despite conceptual overlap. Control 3 defines where the security boundaries sit (which zones exist, including the dedicated industrial firewall isolating PoS/OT equipment); Control 5 defines the specific least-privilege rules enforced at those boundaries. Removing either would leave zones defined with no enforcement, or enforcement rules with no zones to apply them to, so both remain necessary together.

[Group: review this draft together before submission — confirm the merged/rejected control decisions above reflect what the group actually discussed, and adjust the wording so every member can defend it at the viva.]

3. Mandatory Technology Components

For each of the four mandatory technology areas, the group compared all individual member proposals (full proposals in Appendices A–D) directly against each other and selected one as Northbridge's final recommendation.

3.1 VPN Solution

Member 1 proposed Cisco Secure Client with Cisco Secure Firewall using SSL/IKEv2, giving individual usernames, MFA, and role-based ACLs per user. Member 2 proposed Cisco AnyConnect with SSL/IPSec, also per-user with MFA, having considered and rejected

OpenVPN Access Server for weaker integration with a Cisco firewall stack. Member 3 proposed Fortinet FortiGate SSL-VPN with FortiClient and FortiToken MFA, having considered and rejected WireGuard despite its speed and cost advantage, since it lacks the mature enterprise AAA integration a bank needs. Member 4 proposed Palo Alto GlobalProtect SSL/IPSec with per-user MFA and Host Information Profile (HIP) checks that verify OS patch level and antivirus status before a device is allowed to tunnel in, having considered and rejected Fortinet FortiGate SSL-VPN specifically to avoid concentrating VPN, firewall, and authentication on a single vendor.

The group selected Member 4's Palo Alto GlobalProtect proposal. The scenario explicitly states that Northbridge allows staff to work from home on personal devices and phones with no guidance or rules in place — GlobalProtect's HIP check is the only one of the four proposals that inspects the connecting device itself before granting access, directly closing that specific, named gap rather than only authenticating the user. Member 1's and Member 2's Cisco proposals are both solid, individually-accountable, MFA-enforced VPNs, and their convergence on Cisco was a real point in favour of standardising the whole stack on one vendor; the group weighed this but judged the endpoint-compliance capability more directly tied to a named scenario weakness than the integration convenience of staying single-vendor. Member 3's Fortinet proposal was not selected for the same single-vendor-concentration reason Member 4 raised against it.

3.2 AAA Solution

Member 1 and Member 2 independently proposed Cisco Identity Services Engine (ISE) with RADIUS for network/VPN authentication and TACACS+ for device administration. Member 3 proposed FortiAuthenticator with RADIUS, having considered and rejected Microsoft NPS with Active Directory despite its lower cost, since NPS has no TACACS+ capability and would leave device-administration actions on switches/routers unaccountable. Member 4 proposed Aruba ClearPass Policy Manager (RADIUS + TACACS+, AD-integrated) with ClearPass OnGuard for endpoint posture assessment, having considered and rejected Microsoft NPS for the same TACACS+ gap Member 3 identified.

Two members independently converging on Cisco ISE is a meaningful signal, and the group weighed it seriously — ISE is a safe, well-integrated choice, especially if the VPN in 3.1 had also been Cisco. However, since the group selected Palo Alto GlobalProtect for VPN specifically for its HIP endpoint-compliance checking, the group selected Aruba ClearPass for AAA to match: ClearPass OnGuard performs the same endpoint-posture philosophy for local/branch network access that GlobalProtect's HIP performs for remote access, giving Northbridge one consistent compliance-checking approach across both access paths rather than a compliance check on remote access only. FortiAuthenticator was not selected, as it does not offer this posture-assessment capability and was proposed independently of the winning VPN vendor.

3.3 Secure Network Architecture

Member 1 proposed a nine-zone segmented architecture (Internet, Public DMZ, Employee, Core Banking, Database, Third-Party Payment, Management, Guest Wi-Fi, Remote VPN

Users) using perimeter and internal segmentation firewalls. Member 2 proposed a simpler three-tier design (perimeter NGFW with DMZ, plus an internal firewall separating core banking, branch/staff, guest Wi-Fi, and PoS zones), having considered and rejected a single-firewall-plus-ACLs design for lacking stateful inspection between zones. Member 3 proposed a back-to-back dual-firewall design, having considered and rejected a single collapsed NGFW enforcing zones logically, on the grounds that one device becomes a single point of both compromise and failure for a bank. Member 4 proposed a three-tier Palo Alto firewall structure with a dedicated industrial firewall specifically in front of point-of-service and branch support equipment, and the most granular zone set of the four proposals (including a separate zone per branch VLAN and a dedicated partner zone for the two payment processors), having considered and rejected a single collapsed NGFW for the same single-point-of-failure reason Member 3 raised.

The group selected Member 4's architecture. All four proposals correctly segment the flat network, but Member 4's is the only one that specifically isolates point-of-service/OT equipment behind its own dedicated industrial firewall — directly matching the scenario's explicit statement that "point-of-service support equipment" shares the same flat space as everything else. It is also the only proposal with a per-branch VLAN, meaning a ransomware infection at one branch (as in Threat 3) cannot spread to a peer branch, not just to head office. Member 1's nine-zone design is strong and shares the same third-party payment isolation idea, but does not separate PoS equipment or individual branches as granularly. Member 2's and Member 3's proposals were judged too coarse for the specific PoS and branch-to-branch risks the scenario names.

3.4 IDS/IPS Solution

Member 1 proposed Cisco Secure Firewall IPS / Snort 3 deployed at strategic network boundaries. Member 2 proposed Suricata (or a commercial NGFW-integrated IPS module) deployed in-line at internal firewall choke points, having considered and rejected a passive Snort IDS-only deployment for leaving the bank reacting after the fact rather than actively blocking ransomware spread in real time. Member 3 proposed the FortiGuard IPS engine in-line on both firewalls, paired with a secondary passive Suricata sensor on a SPAN port at the head office for added visibility, having considered and rejected a fully passive-only deployment for the same real-time-blocking reason Member 2 raised. Member 4 proposed Palo Alto Threat Prevention IPS deployed in-line on both firewalls, paired with Cisco Stealthwatch flow-based anomaly detection (using NetFlow/IPFIX from firewalls and switches) to catch lateral movement that signature-based detection alone would miss, having considered and rejected a passive-only deployment for the same reason.

All four members independently agreed that passive-only detection is insufficient given Northbridge cannot staff a 24/7 response team — that convergence gave the group high confidence that in-line, actively blocking IPS is non-negotiable regardless of vendor. The group selected Member 4's proposal specifically because it pairs the in-line IPS with flow-based behavioural analytics rather than a second passive signature-based sensor (Member 3's approach): both Threat 6 (compromised branch equipment) and Threat 8 (physical access to

infrastructure) in Section 1 describe an attacker who is already inside the network before any signature would fire, which flow analysis is specifically suited to catch. This also let the group avoid deploying Member 3's passive Suricata sensor as a separate product, folding that visibility need into Stealthwatch instead (see the Control Minimization write-up in 2.4).

[Group: this draft is built directly from what's actually in Appendices A-D. Read it together, correct anything that doesn't match your real discussion, and make sure whoever presents this section at the viva can explain every comparison — including why Member 1, 2, and 3's own proposals were not selected — in their own words.]

4. Individual Network Hardening Configurations

Member 1 - IT24100139 - Pinthu D.I.U.

The text includes two separate configurations in Cisco Packet Tracer. The first configuration is specifically linked to Threat 2, while the second one addresses Threat 1 and shows an example of centralized AAA.

4.1 Configuration 1 - An extended ACL with the least-privilege principle for integration with third-party payment systems

Plan-linked configuration

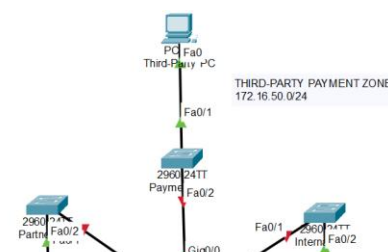
Element	Content
Purpose	Restrict the third-party payment partner so it can reach only the payment-integration server over the required HTTPS service while preventing direct access to the internal/core network.
Threat Addressed	Threat 2 - Third-party payment integration compromise leading to unauthorized access/data breach.
Control Link	Least-Privilege Firewall/ACL Rules.
Security Principle	Required source → required destination → required protocol → required port; deny unnecessary access.

The topology and addressing for Packet Tracer

Device/Zone	IP Address	Mask	Default Gateway
Third-Party PC	172.16.50.10	255.255.255.0	172.16.50.1
Payment Server	10.20.30.10	255.255.255.0	10.20.30.1
Internal/Core Server	10.20.40.10	255.255.255.0	10.20.40.1

Router interfaces:

- R1, interface G0/0 — 172.16.50.1/24 (Third-Party Payment)
- R1 G0/1, 10.20.30.1/24 (Payment Zone)
- R1 G0/2, 10.20.40.1/24 (Internal Zone)



Router Initial Configuration

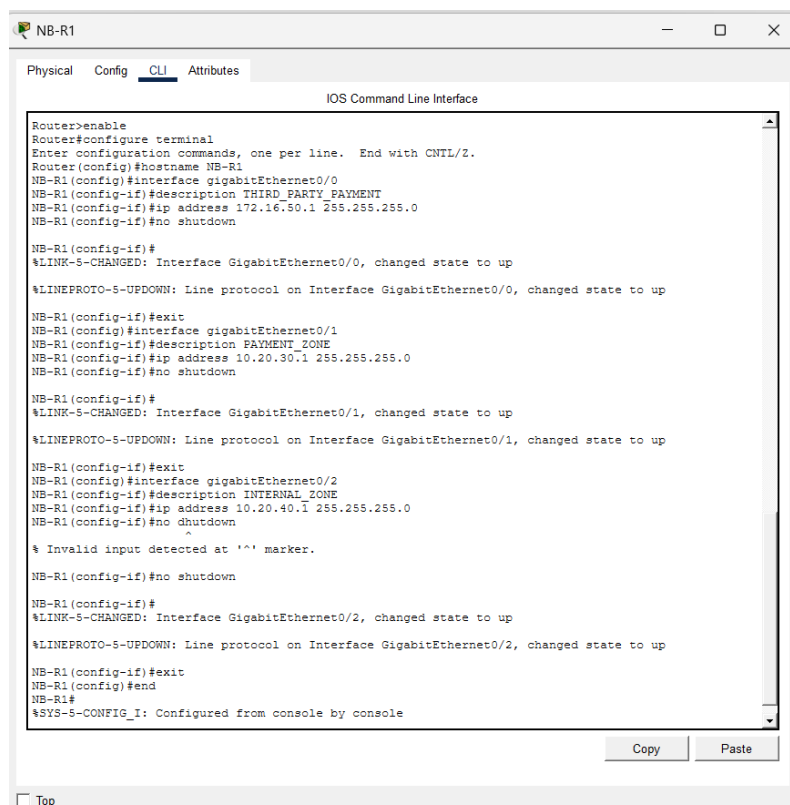
Figure 1: : Packet Tracer topology for third-party payment network segmentation

```
enable
configure terminal
hostname NB-R1

interface gigabitEthernet0/0
description THIRD_PARTY_PAYMENT
ip address 172.16.50.1 255.255.255.0
no shutdown
exit

interface gigabitEthernet0/1
description PAYMENT_ZONE
ip address 10.20.30.1 255.255.255.0
no shutdown
exit

interface gigabitEthernet0/2
description INTERNAL_ZONE
ip address 10.20.40.1 255.255.255.0
no shutdown
exit
```



```

NB-R1#show ip interface brief
Interface      IP-Address      OK? Method Status  Protocol
GigabitEthernet0/0  172.16.50.1    YES manual up      up
GigabitEthernet0/1  10.20.30.1     YES manual up      up
GigabitEthernet0/2  10.20.40.1     YES manual up      up
Vlan1          unassigned     YES unset  administratively down down
NB-R1#

```

Figure 2: Router interfaces configured for the three security zones

Extended ACL Configuration

```

ip access-list extended PAYMENT-PARTNER-IN
 permit tcp host 172.16.50.10 host 10.20.30.10 eq 443
 deny ip 172.16.50.0 0.0.0.255 10.20.40.0 0.0.0.255
 deny ip any any
exit

```

```

interface gigabitEthernet0/0
 ip access-group PAYMENT-PARTNER-IN in
exit

```

```

end
copy running-config startup-config

```

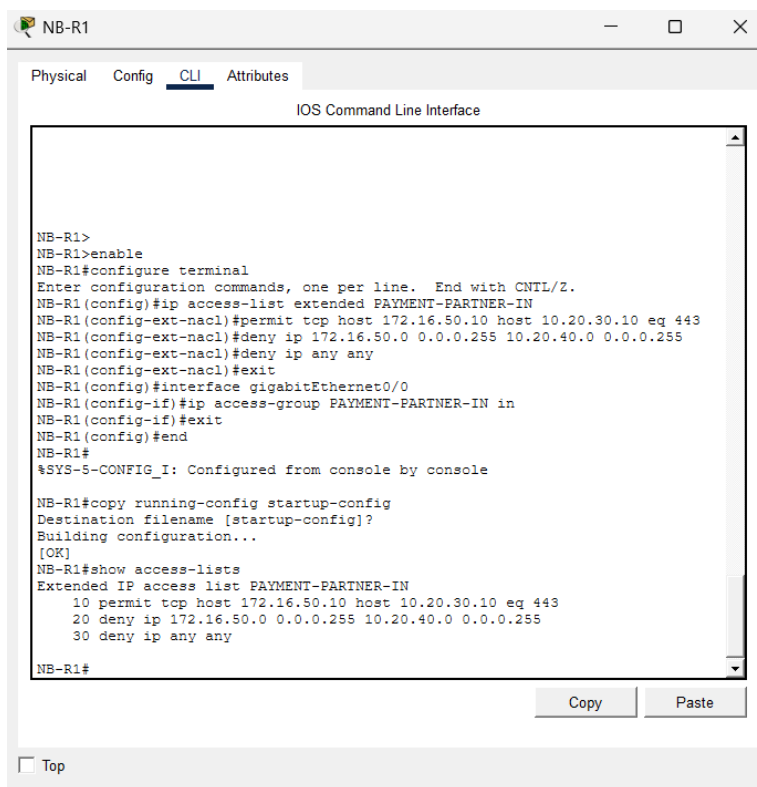


Figure 3: Least-privilege extended ACL for the third-party payment partner

Verification

```
show access-lists
show ip interface gigabitEthernet0/0
```

```
NB-R1#show ip interface gigabitEthernet0/0
GigabitEthernet0/0 is up, line protocol is up (connected)
Internet address is 172.16.50.1/24
Broadcast address is 255.255.255.255
Address determined by setup command
MTU is 1500 bytes
Helper address is not set
Directed broadcast forwarding is disabled
Outgoing access list is not set
Inbound access list is PAYMENT-PARTNER-IN
Proxy ARP is enabled
Security level is default
Split horizon is enabled
ICMP redirects are always sent
ICMP unreachable are always sent
ICMP mask replies are never sent
IP fast switching is disabled

NB-R1#show access-lists PAYMENT-PARTNER-IN
Extended IP access list PAYMENT-PARTNER-IN
  permit tcp host 172.16.50.10 host 10.20.30.10 eq 443
  deny ip 172.16.50.0 0.0.0.255 10.20.40.0 0.0.0.255
  deny ip any any
```

Figure 4: Verification of the ACL applied inbound on the third-party interface

Functional Validation

- From the Third-Party PC, access https://10.20.30.10. This should be permitted when HTTPS is enabled on the Payment Server.
- Attempt to reach 10.20.40.10 in the Internal/Core network. This should be blocked.

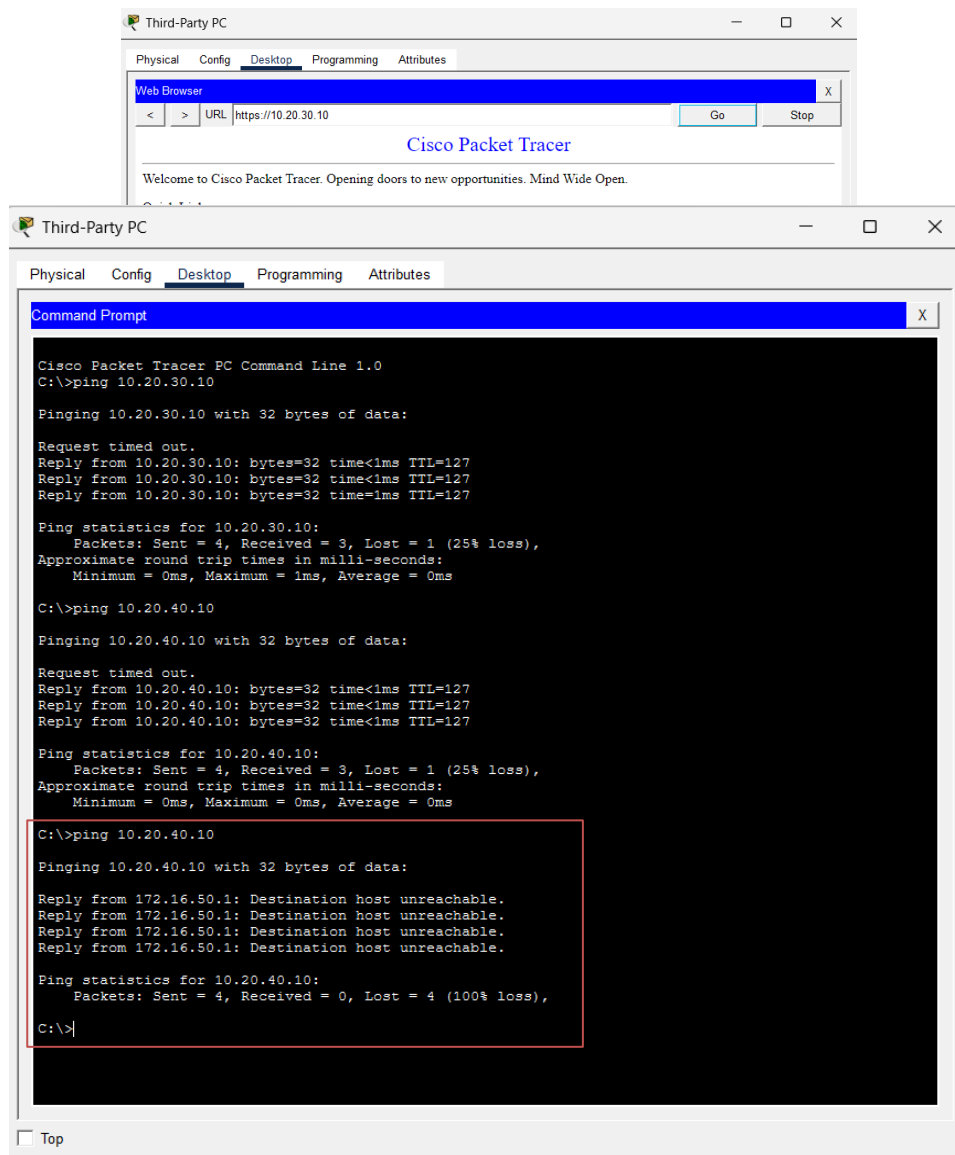


Figure 6: ACL preventing the third-party network from accessing the internal core network

```
NB-R1>
NB-R1>show access-lists PAYMENT-PARTNER-IN
^
% Invalid input detected at '^' marker.

NB-R1>enable
NB-R1#show access-lists PAYMENT-PARTNER-IN
Extended IP access list PAYMENT-PARTNER-IN
    permit tcp host 172.16.50.10 host 10.20.30.10 eq 443 (20 match(es))
    deny ip 172.16.50.0 0.0.0.255 10.20.40.0 0.0.0.255 (8 match(es))
    deny ip any any
NB-R1#
```

Figure 7: ACL match counters demonstrating permitted and denied traffic

Result

Using this setup, the third-party payment partner is able to access the payment-integration server only via the necessary HTTPS service. The access control list stops the third-party network from being able to communicate freely with Northbridge's internal network. Thus, the least-privilege network-access control suggested for Threat 2 is implemented and the potential impact of a compromise of a payment provider through the trusted integration connection is limited.

4.2 Configuration 2 - The use of RADIUS for centralised AAA authentication

Element	Content
Purpose	Provide centralized authentication for administrative access to the router using individual identities rather than relying only on separate unmanaged local accounts.
Threat Addressed	Threat 1 - Credential compromise through social engineering and weak password practices.
Security Benefit	Improves individual accountability and centralizes authentication. It complements MFA and password-security controls proposed for production.

The topology and addressing for Packet Tracer

Device IP	Address	Role
Router R1	10.10.10.1	Network device using centralized AAA
AAA Server	10.10.10.100	RADIUS authentication server
Admin PC	10.10.10.10	Administrative client

- Admin PC (10.10.10.10)
- Switch
- Router R1 (10.10.10.1)
- AAA Server (10.10.10.100)

Configure the AAA Server

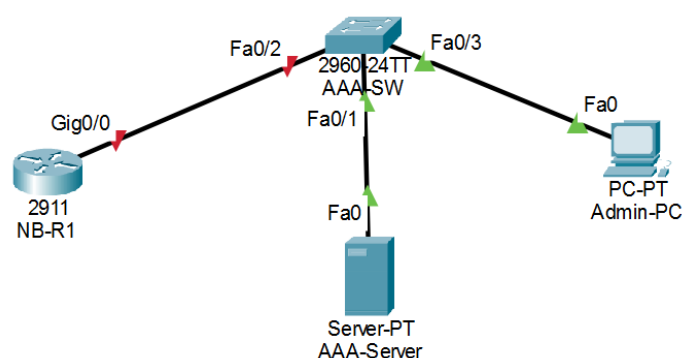


Figure 8: Centralized RADIUS AAA network topology

Router AAA and RADIUS Configuration

```
enable
configure terminal
hostname NB-R1
aaa new-model
username localadmin privilege 15 secret LocalFallback2026!
radius-server host 10.10.10.100 key NBRadius2026!
aaa authentication login default group radius local
```

With this authentication method the router first tries to carry out RADIUS authentication and if the RADIUS server is not available it uses the local fallback account.

AAA-Server

Physical Config **Services** Desktop Programming Attributes

SERVICES

- HTTP
- DHCP
- DHCPv6
- TFTP
- DNS
- SYSLOG
- AAA**
- NTP
- EMAIL
- FTP
- IoT
- VM Management
- Radius EAP
- PRP

AAA

Service ☒ On ☐ Off Radius Port 1645

Network Configuration

Client Name Client IP

Secret ServerType Radius

	Client Name	Client IP	Server Type	Key	
1	NB-R1	10.10.10.1	Radius	NBRadius2026!	Add

Save

Remove

User Setup

Username Password

	Username	Password	
1	radiusadmin	Admin2026!	Add

Save

Remove

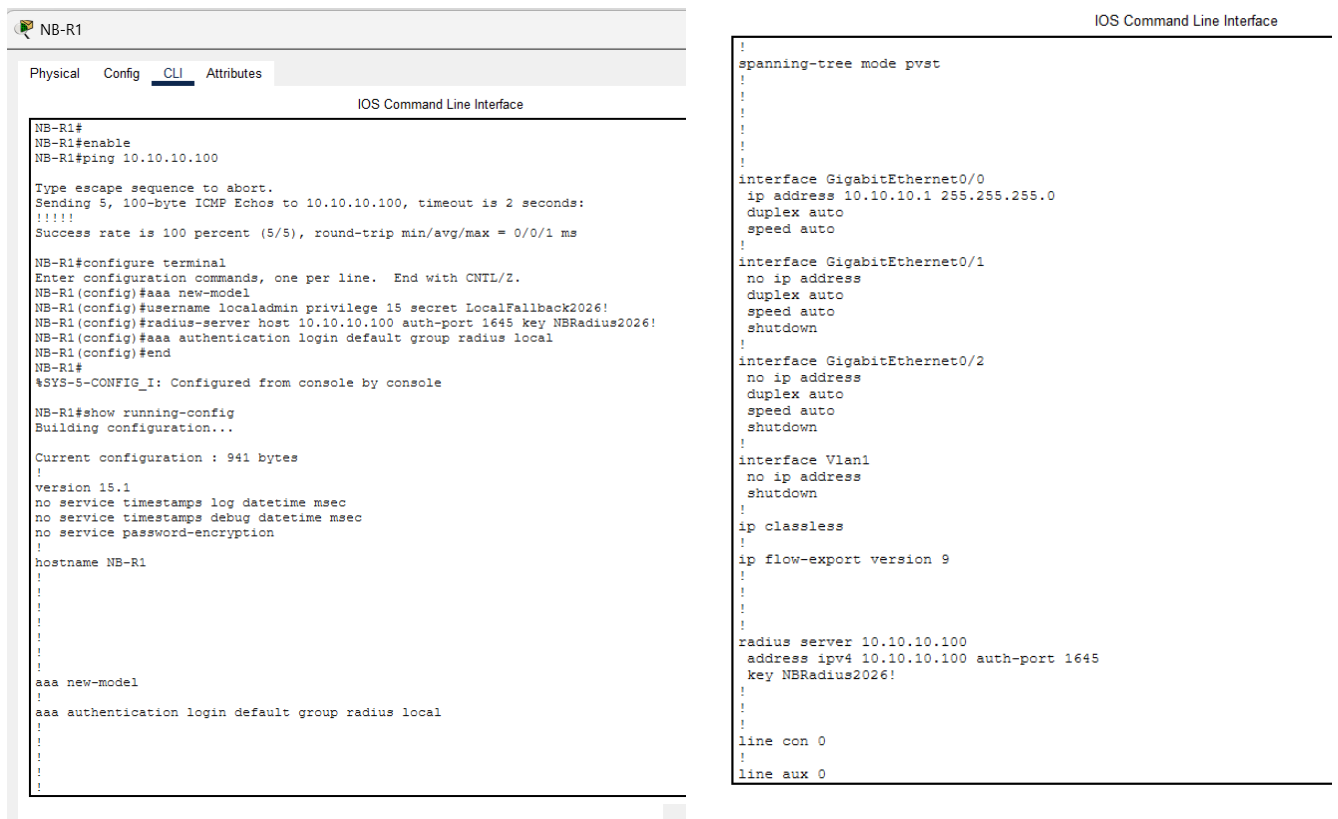


Figure 9: RADIUS-based centralized AAA authentication configured on NB-R1

Configure SSH

```
ip domain-name northbridge.local
crypto key generate rsa
ip ssh version 2
```

```
line vty 0 4
 login authentication default
 transport input ssh
exit
```

```
end
copy running-config startup-config
```

```
NB-R1#
NB-R1#enable
NB-R1#ping 10.10.10.100

Type escape sequence to abort.
Sending 5, 100-byte ICMP Echos to 10.10.10.100, timeout is 2 seconds:
!!!!
Success rate is 100 percent (5/5), round-trip min/avg/max = 0/1/5 ms

NB-R1#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
NB-R1(config)#
NB-R1(config)#ip domain-name northbridge.local
NB-R1(config)#
NB-R1(config)#crypto key generate rsa
The name for the keys will be: NB-R1.northbridge.local
Choose the size of the key modulus in the range of 360 to 4096 for your
General Purpose Keys. Choosing a key modulus greater than 512 may take
a few minutes.
How many bits in the modulus [512]: 1024
```

Verification

```
show running-config
show ip ssh
```

Figure 10: SSH version 2 enabled for secure administrative access

Confirm that the running configuration contains aaa new-model and aaa authentication login default group radius local.

The figure consists of two terminal screenshots. The left screenshot shows the output of the 'show running-config' command on a Cisco router (NB-R1). The output displays the current configuration, including the 'aaa new-model' and 'aaa authentication login default group radius local' commands. The right screenshot shows the output of the 'show ip ssh' command, which confirms that SSH is enabled with version 2.0 and that the authentication timeout is 120 seconds with 3 retries.

```
IOS Command Line Interface
NB-R1#
NB-R1#
NB-R1#show running-config
Building configuration...

Current configuration : 1042 bytes
!
version 15.1
no service timestamps log datetime msec
no service timestamps debug datetime msec
no service password-encryption
!
hostname NB-R1
!
!
!
!
!
!
aaa new-model
!
aaa authentication login default group radius local
!
!
!
!
!
!
ip cef
no ipv6 cef
!
!
!
username localadmin privilege 15 secret 5 $1$mERr$PNHemb1pC2N2eU7Db81cQ0
!
!
license udi pid CISCO2911/K9 sn FTX1524T6W9-
!
!

speed auto
!
interface GigabitEthernet0/1
no ip address
duplex auto
speed auto
shutdown
!
interface GigabitEthernet0/2
no ip address
duplex auto
speed auto
shutdown
!
interface Vlan1
no ip address
shutdown
!
ip classless
!
ip flow-export version 9
!
!
!
radius server 10.10.10.100
address ipv4 10.10.10.100 auth-port 1645
key NBRadius2026!
!
!
!
line con 0
!
line aux 0
!
line vty 0 4
login authentication default
transport input ssh
!
!
!
end
NB-R1#

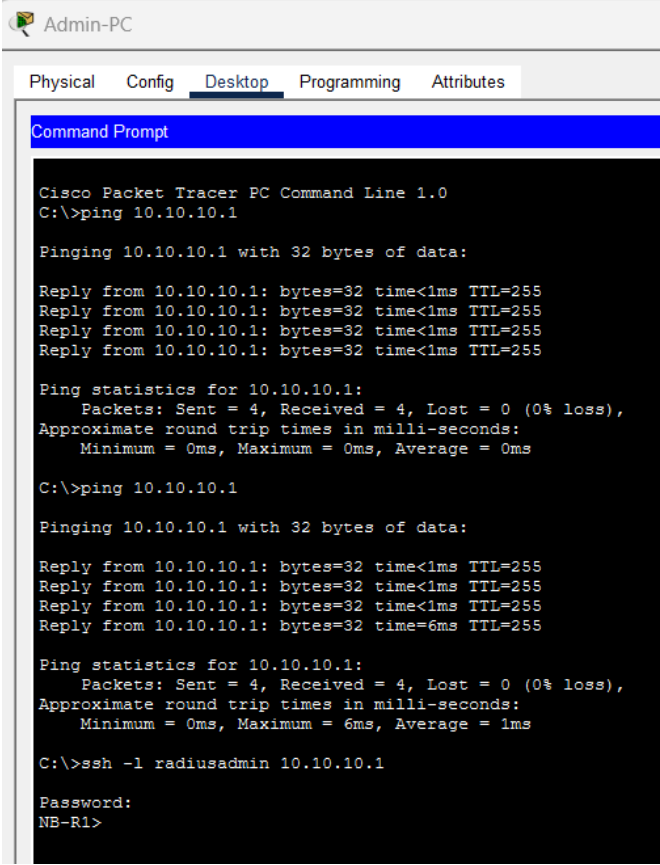
NB-R1#
NB-R1#show ip ssh
SSH Enabled - version 2.0
Authentication timeout: 120 secs; Authentication retries: 3
NB-R1#
```

Figure 11: Verification of centralized AAA and SSH configuration

Authentication Test

```
ssh -l radiusadmin 10.10.10.1
```

Enter the password that has been set up for the individual user on the AAA server, since successful authentication shows that the router is making use of a centrally managed identity.



The screenshot shows the 'Admin-PC' window in Cisco Packet Tracer. The 'Desktop' tab is selected, displaying a 'Command Prompt' window. The command prompt shows the following sequence of commands and outputs:

```
Cisco Packet Tracer PC Command Line 1.0
C:\>ping 10.10.10.1

Pinging 10.10.10.1 with 32 bytes of data:

Reply from 10.10.10.1: bytes=32 time<1ms TTL=255
Reply from 10.10.10.1: bytes=32 time<1ms TTL=255
Reply from 10.10.10.1: bytes=32 time<1ms TTL=255
Reply from 10.10.10.1: bytes=32 time<1ms TTL=255

Ping statistics for 10.10.10.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 0ms, Average = 0ms

C:\>ping 10.10.10.1

Pinging 10.10.10.1 with 32 bytes of data:

Reply from 10.10.10.1: bytes=32 time<1ms TTL=255
Reply from 10.10.10.1: bytes=32 time<1ms TTL=255
Reply from 10.10.10.1: bytes=32 time<1ms TTL=255
Reply from 10.10.10.1: bytes=32 time=6ms TTL=255

Ping statistics for 10.10.10.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 0ms, Maximum = 6ms, Average = 1ms

C:\>ssh -l radiusadmin 10.10.10.1

Password:
NB-R1>
```

To the right of the command prompt, a separate window shows the SSH session details:

```
Password:
NB-R1>exit

[Connection to 10.10.10.1 closed by foreign host]
C:\>ssh -l fakeuser 10.10.10.1

Password:
% Login invalid

Password: |
```

Figure 12: Successful SSH login using the centrally managed RADIUS account

Result

This setup enables centralised authentication when accessing the network devices from an administrative standpoint. Instead of depending solely on separate, unmanaged local accounts, the authentication requests are processed via a central AAA server. It enhances individual accountability and decreases the need for shared credentials. The configuration meets Northbridge's requirements regarding credential security and is compatible with the proposed MFA and password-security measures

Member 2 - IT24101169 - Weligampitiya S.A.S.D.

Configuration 1 (Plan-linked): Port Security

Its purpose: Limits the number and/or type of devices that can attach to an access point on a branch switch, and de-authenticates and disables the access point if an unauthorized device attempts to attach to the access point.

Threat addressed: Threat 1 — ransomware spreading via the unsegmented flat network. Port Security prevents an attacker from inserting a rogue device or replacing a compromised device with a new one and obtaining a secure MAC address to then pivot further into the network.

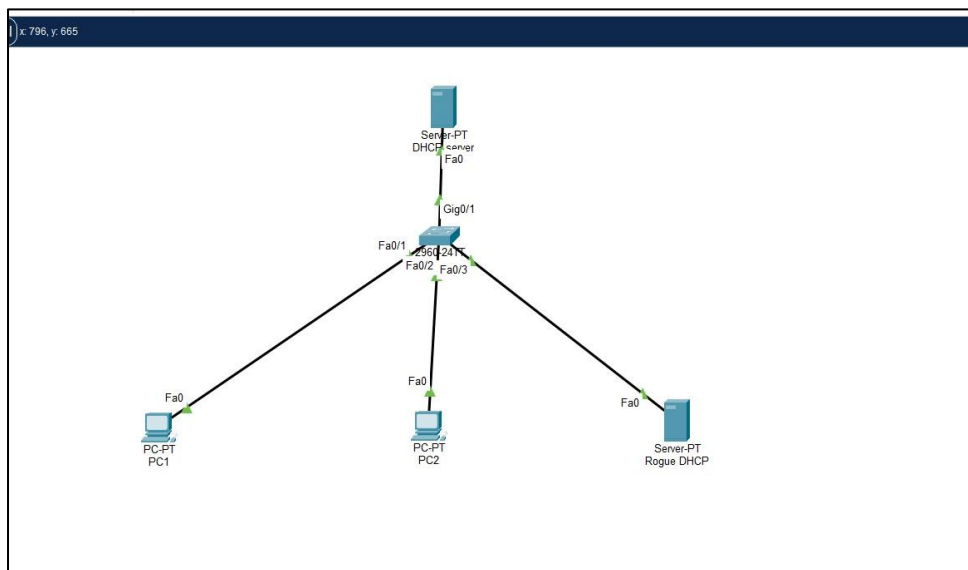


Figure 1: Topology

The screenshot shows the 'DHCP server' configuration window. The 'Services' tab is selected, and the 'DHCP' service is enabled. The configuration details for the 'serverPool' are as follows:

Interface	Service	Pool Name	Default Gateway	DNS Server	Start IP Address	Subnet Mask	Maximum Number of Users	TFTP Server	WLC Address
FastEthernet0	On	serverPool	192.168.1.1	192.168.1.1	192.168.1.10	255.255.255.0	246	0.0.0.0	0.0.0.0

Figure 2: Configure the legitimate DHCP server's pool

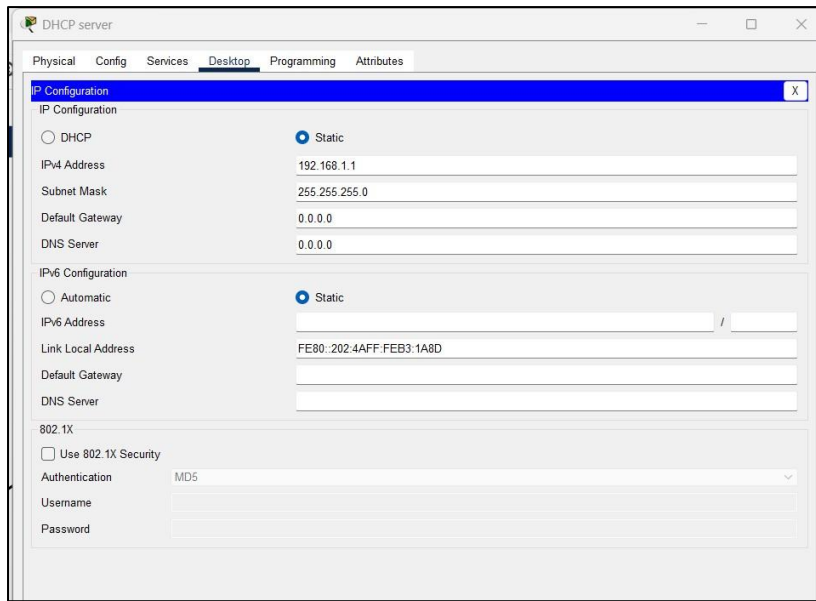


Figure 3: Configure the legitimate DHCP server's pool

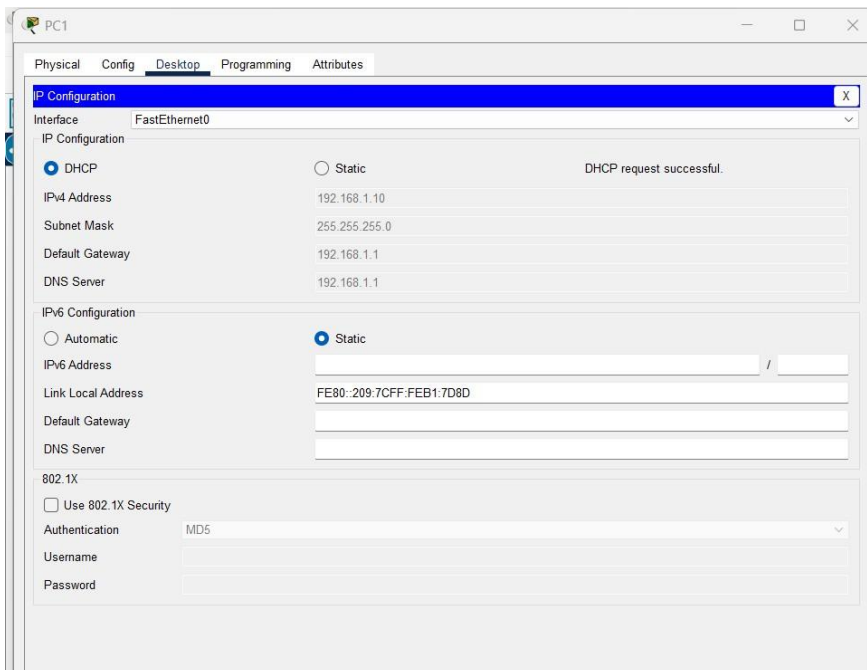


Figure 4: Set PC1 to obtain IP via DHCP

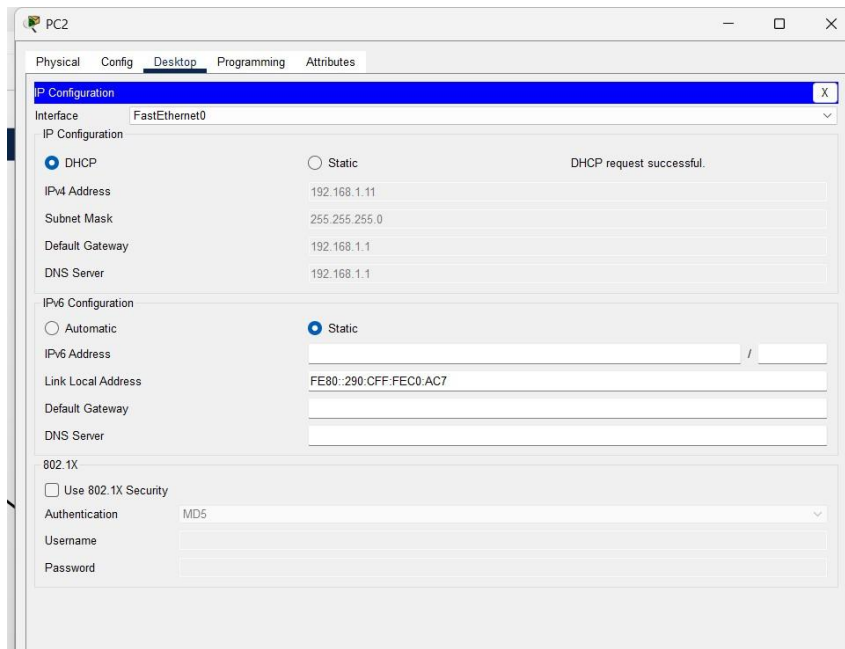


Figure 5: Set PC2 to obtain IP via DHCP

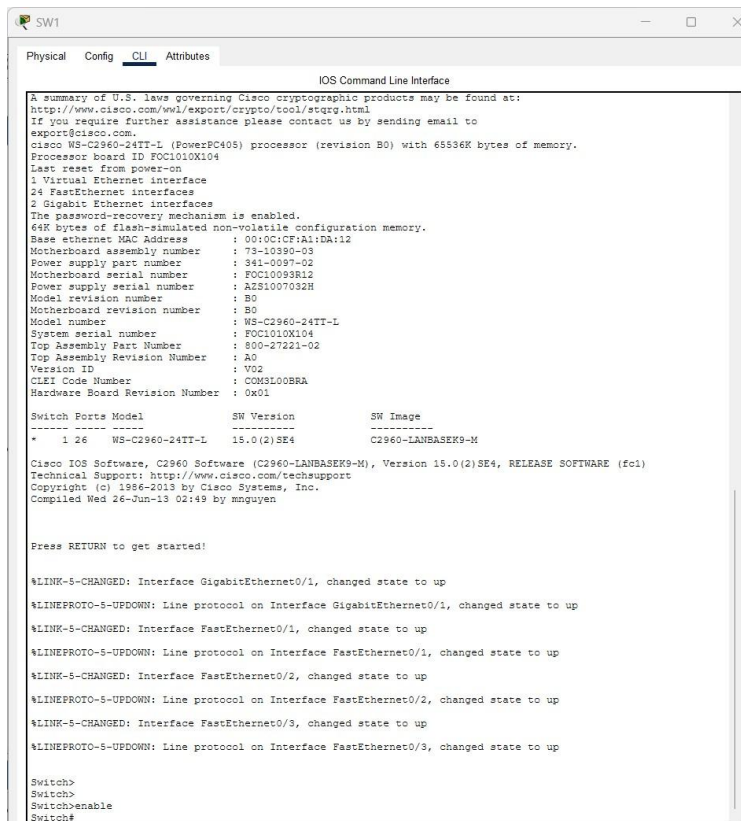


Figure 13: Switch1 configuration

enable

configure terminal

```
%LINK-5-CHANGED: Interface FastEthernet0/2, changed state to up
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/2, changed state to up
%LINK-5-CHANGED: Interface FastEthernet0/3, changed state to up
%LINEPROTO-5-UPDOWN: Line protocol on Interface FastEthernet0/3, changed state to up

Switch>
Switch>enable
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#interface fastEthernet 0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 1
Switch(config-if)#switchport port-security violation shutdown
Switch(config-if)#switchport port-security mac-address sticky
Switch(config-if)#exit
Switch(config)#
```

☐ Top

Figure 14:Port Security Commands

interface fastEthernet 0/1

switchport mode access

switchport port-security

switchport port-security maximum 1

switchport port-security violation shutdown

switchport port-security mac-address sticky

exit

exit

```

Switch>
Switch>
Switch>enable
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#interface fastEthernet 0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 1
Switch(config-if)#switchport port-security violation shutdown
Switch(config-if)#switchport port-security mac-address sticky
Switch(config-if)#exit
Switch(config)#exit
Switch#
%SYS-5-CONFIG_I: Configured from console by console

Switch#show port-security interface fastEthernet 0/1
Port Security          : Enabled
Port Status            : Secure-up
Violation Mode         : Shutdown
Aging Time             : 0 mins
Aging Type             : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses  : 1
Total MAC Addresses    : 0
Configured MAC Addresses : 0
Sticky MAC Addresses   : 0
Last Source Address:Vlan : 0000.0000.0000:0
Security Violation Count : 0

Switch#show interfaces fastEthernet 0/1
FastEthernet0/1 is up, line protocol is up (connected)
Hardware is Lance, address is 0060.70d2.0201 (bia 0060.70d2.0201)
BW 100000 Kbit, DLY 100 usec,
    reliability 255/255, txload 1/255, rxload 1/255
Encapsulation ARPA, loopback not set
Keepalive set (10 sec)
Full-duplex, 100Mb/s
input flow-control is off, output flow-control is off
ARP type: ARPA, ARP Timeout 00:04:00
Last input 00:00:08, output 00:00:05, output hang never
Last clearing of "show interface" counters never
Input queue: 0/75/0/0 (size/max/drops/flushes); Total output drops: 0
Queueing strategy: fifo
Output queue :0/40 (size/max)
5 minute input rate 0 bits/sec, 0 packets/sec
5 minute output rate 0 bits/sec, 0 packets/sec
 956 packets input, 193351 bytes, 0 no buffer
Received 956 broadcasts, 0 runts, 0 giants, 0 throttles
 0 input errors, 0 CRC, 0 frame, 0 overrun, 0 ignored, 0 abort
 0 watchdog, 0 multicast, 0 pause input
 0 input packets with dribble condition detected
2357 packets output, 263570 bytes, 0 underruns
--More--

```

Figure 15:Port Security command sand verification

show port-security interface fastEthernet 0/1

```

Switch#show interfaces fastEthernet 0/1
FastEthernet0/1 is up, line protocol is up (connected)
Hardware is Lance, address is 0060.70d2.0201 (bia 0060.70d2.0201)
BW 100000 Kbit, DLY 100 usec,
    reliability 255/255, txload 1/255, rxload 1/255
Encapsulation ARPA, loopback not set
Keepalive set (10 sec)
Full-duplex, 100Mb/s
input flow-control is off, output flow-control is off
ARP type: ARPA, ARP Timeout 00:04:00
Last input 00:00:08, output 00:00:05, output hang never
Last clearing of "show interface" counters never
Input queue: 0/75/0/0 (size/max/drops/flushes); Total output drops: 0
Queueing strategy: fifo
Output queue :0/40 (size/max)
5 minute input rate 0 bits/sec, 0 packets/sec
5 minute output rate 0 bits/sec, 0 packets/sec
 956 packets input, 193351 bytes, 0 no buffer
Received 956 broadcasts, 0 runts, 0 giants, 0 throttles
 0 input errors, 0 CRC, 0 frame, 0 overrun, 0 ignored, 0 abort
 0 watchdog, 0 multicast, 0 pause input
 0 input packets with dribble condition detected
2357 packets output, 263570 bytes, 0 underruns
 0 output errors, 0 collisions, 10 interface resets

Switch#show interfaces fastEthernet 0/1 status

```

Port	Name	Status	Vlan	Duplex	Speed	Type
Fa0/1		connected	1	a-full	a-100	10/100BaseTX

```

Switch#

```

Figure 16:port security verifications

show interfaces fastEthernet 0/1 status

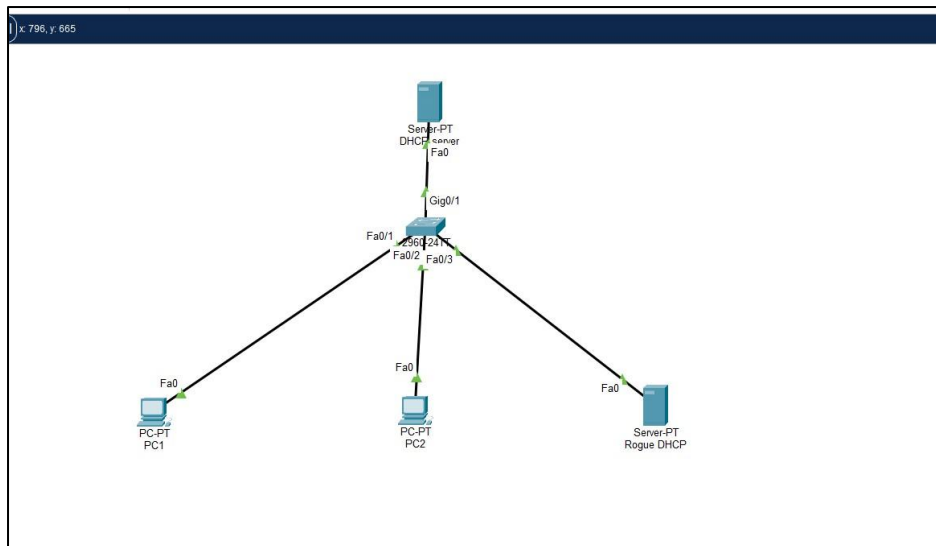


Figure 17:Port Security output

Control Validation - Simulated Unauthorized Device

```

Switch>
Switch>
Switch>enable
Switch#configure terminal
Enter configuration commands, one per line. End with CNTRL/Z.
Switch(config)#interface fastEthernet 0/1
Switch(config-if)#switchport mode access
Switch(config-if)#switchport port-security
Switch(config-if)#switchport port-security maximum 1
Switch(config-if)#switchport port-security violation shutdown
Switch(config-if)#switchport port-security mac-address sticky
Switch(config-if)#exit
Switch(config)#exit
Switch#
%SYS-5-CONFIG_I: Configured from console by console

Switch#show port-security interface fastEthernet 0/1
Port Security          : Enabled
Port Status            : Secure-up
Violation Mode         : Shutdown
Aging Time             : 0 mins
Aging Type             : Absolute
SecureStatic Address Aging : Disabled
Maximum MAC Addresses  : 1
Total MAC Addresses    : 0
Configured MAC Addresses : 0
Sticky MAC Addresses   : 0
Last Source Address:Vlan : 0000.0000.0000:0
Security Violation Count : 0

Switch#show interfaces fastEthernet 0/1
FastEthernet0/1 is up, line protocol is up (connected)
  Hardware is Lance, address is 0060.70d2.0201 (bia 0060.70d2.0201)
  BW 100000 Kbit, DLY 100 usec,
    reliability 255/255, txload 1/255, rxload 1/255
  Encapsulation ARPA, loopback not set
  Keepalive set (10 sec)
  Full-duplex, 100Mb/s
  input flow-control is off, output flow-control is off
  ARP type: ARPA, ARP Timeout 00:04:00
  Last input 00:00:08, output 00:00:05, output hang never
  Last clearing of "show interface" counters never
  Input queue: 0/75/0/0 (size/max/drops/flushes): Total output drops: 0
  Queueing strategy: fifo
  Output queue : 0/40 (size/max)
  5 minute input rate 0 bits/sec, 0 packets/sec
  5 minute output rate 0 bits/sec, 0 packets/sec
    956 packets input, 193351 bytes, 0 no buffer
    Received 956 broadcasts, 0 runts, 0 giants, 0 throttles
    0 input errors, 0 CRC, 0 frame, 0 overrun, 0 ignored, 0 abort
    0 watchdog, 0 multicast, 0 pause input
    0 input packets with dribble condition detected
  2357 packets output, 263570 bytes, 0 underruns
  --More--
  
```

Figure 18:Configuration Applied

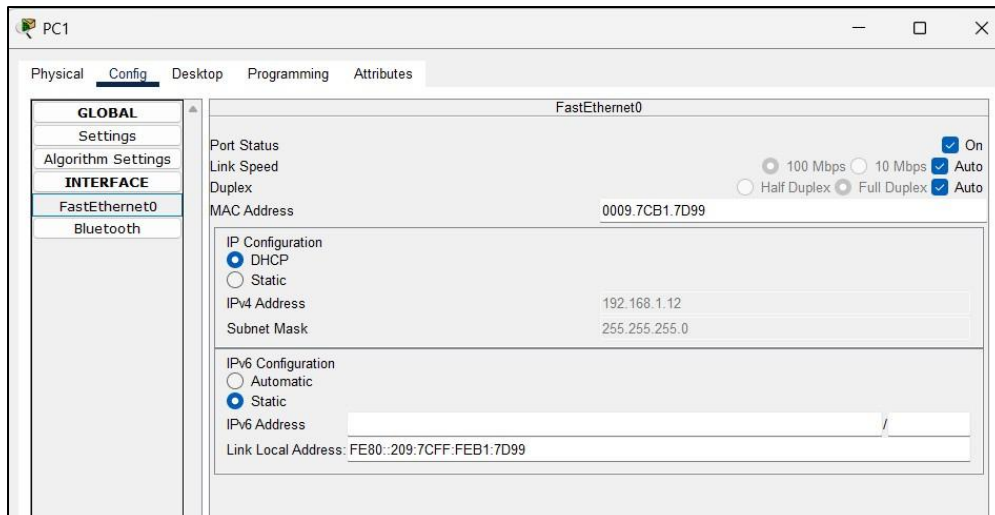


Figure 19:changed MAC Address

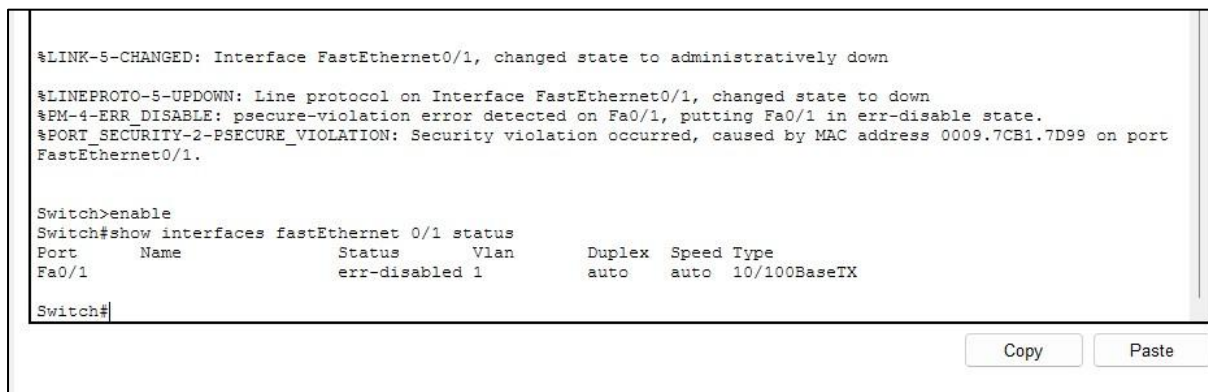


Figure 20:Enforcement Verification

show interfaces fastEthernet 0/1 status

Member 3 - IT24102358 – Silva D.P.L.T.D.

Configuration 1 (Plan-linked): AAA Centralized Authentication with RADIUS and SSH-only Management

Its purpose: Instead of the local shared password on every networked computer, it uses centrally verified logins that are stored on a single AAA server such that every admin login corresponds to an individual person. There will be a fallback local account just in case there is a problem with the connection between the main office and the branch such that the administrators can still have access to branch equipment. Telnet is replaced by SSH since management credentials should no longer travel through the network unencrypted.

Threat addressed: Threat 2 - Access by an unauthorized person to the core banking systems through the branch network devices. This threat relies on the hacker's ability to gain access to the branch switching devices using shared or recycled local login credentials; centralized authentication eliminates the use of shared login credentials entirely and creates the individual audit trail that Northbridge lacks. It will also address Threat 1 since it enables the creation of the individualized MFA and VPN accounts.

Plan link: Implements the group control "Centralized AAA (RADIUS/TACACS+) replacing local and shared device accounts" from the combined layered security plan in Section 2.

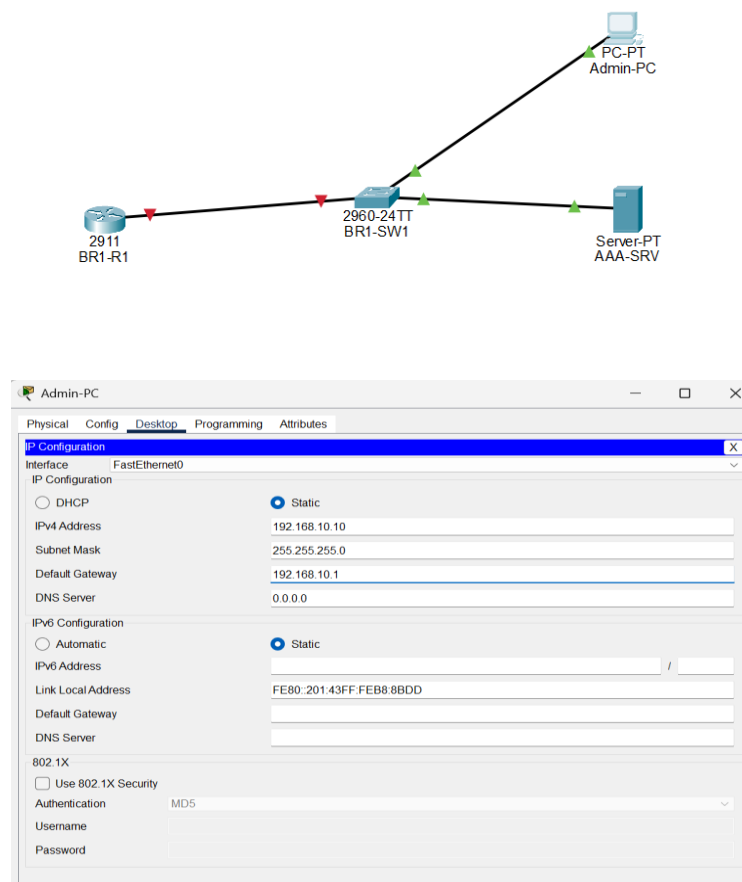


Figure 4.1: Topology used for the AAA configuration

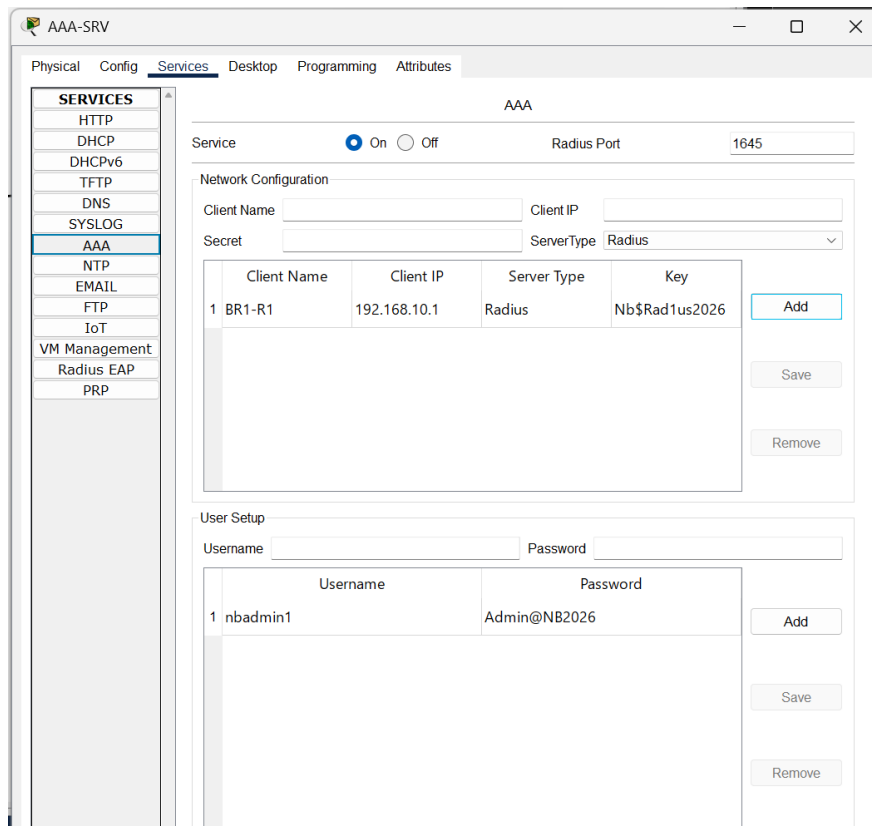


Figure 4.2: AAA (RADIUS) server configuration

Router configuration commands:

```
enable

configure terminal

hostname BR1-R1

ip domain-name northbridge.lk


interface gigabitEthernet 0/0

ip address 192.168.10.1 255.255.255.0

no shutdown

exit


username nb-local privilege 15 secret Local@Fallback1

enable secret Enable@NB2026

service password-encryption
```

```

radius-server host 192.168.10.100 auth-port 1645 key Nb$Radius2026

aaa new-model

aaa authentication login default group radius local

crypto key generate rsa

1024

ip ssh version 2

line vty 0 4

    transport input ssh

    login authentication default

    exec-timeout 5 0

    exit

line console 0

    login authentication default

    exit

end

write memory

```

```

BR1-R1(config)#
BR1-R1(config)#aaa new-model
BR1-R1(config)#aaa authentication login default group radius local
BR1-R1(config)#

```

Figure 4.3: AAA and RADIUS configuration commands

```

BR1-R1(config)#crypto key generate rsa
The name for the keys will be: BR1-R1.northbridge.1k
Choose the size of the key modulus in the range of 360 to 4096 for your
General Purpose Keys. Choosing a key modulus greater than 512 may take
a few minutes.
How many bits in the modulus [512]: 1024

```

Figure 4.4: SSH enabled on the management plane

Verification commands:

```

show running-config

show ip ssh

show users

```

```
BR1-R1#show running-config
Building configuration...

Current configuration : 1119 bytes
!
version 15.1
no service timestamps log datetime msec
no service timestamps debug datetime msec
service password-encryption
!
hostname BR1-R1
!
!
!
enable secret 5 $1$mERr$1GanLZ1ra/J0/BODP8CCx.
!
!
!
!
!
aaa new-model
!
aaa authentication login default group radius local
!
!
!
!
!
ip cef
no ipv6 cef
!
!
!
username nb-local privilege 15 secret 5 $1$mERr$Bx0xeScmg8oIYdQ2rtznZF0
!
!
!
license udi pid CISCO2911/K9 sn FTX15242O8R-
!
!
!
```

Figure 4.5: Verification of the AAA configuration

```
BR1-R1#show ip ssh
SSH Enabled - version 2.0
Authentication timeout: 120 secs; Authentication retries: 3
BR1-R1#
```

Figure 4.6: Verification that SSH is enabled

Control validation - authentication against the central server:

```
C:\>ping 192.168.10.1

Pinging 192.168.10.1 with 32 bytes of data:

Reply from 192.168.10.1: bytes=32 time<1ms TTL=255
Reply from 192.168.10.1: bytes=32 time<1ms TTL=255
Reply from 192.168.10.1: bytes=32 time<1ms TTL=255
Reply from 192.168.10.1: bytes=32 time<1ms TTL=255

Ping statistics for 192.168.10.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms

C:\>ssh -l nbadmin1 192.168.10.1

Password:
BR1-R1>
```

Figure 4.7: Successful login using a credential held only on the AAA server

```

C:\>ssh -l nbadmin1 192.168.10.1

Password:
% Login invalid

Password:

[Connection to 192.168.10.1 closed by foreign host]

```

Figure 4.8: Authentication failure with an invalid credential

```

[Connection to 192.168.10.1 closed by foreign host]
C:\>ssh -l nb-local 192.168.10.1

Password:
BR1-R1>

```

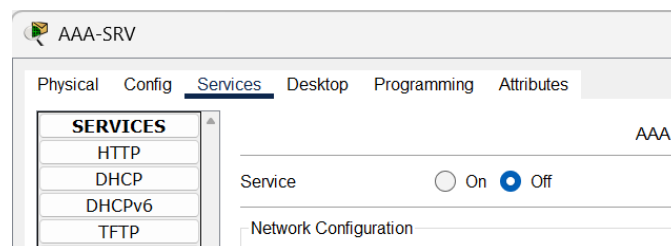


Figure 4.9: Local fallback working when the AAA server is unreachable

Result expected in terms of verification: The configuration is supposed to display aaa new-model with login method list RADIUS group then local and show ip ssh displays SSH version 2 enabled. Log-in using nbadmin1 is possible even though the name does not exist on any part of the router thus confirming that authentication is done centrally and that log-in using the wrong password fails. When the AAA service on the server is disabled, log-in using nb-local account works thus indicating that the alternative works and there is no introduction of SPOF for branch equipment.

Configuration 2: Extended ACL Zone Enforcement Between the Guest, Branch and Core Banking Zones

Its purpose: Uses extended access control lists with names to create boundaries between three zones that currently use one flat addressing scheme: the guest Wi-Fi zone, the branch employee zone, and the core banking server zone. Access from the guest zone to the internal zones is blocked, while the branch employees have access to the core banking server only via the required application ports but not via any other protocol.

Problems in the real world: Northbridge has allowed its networks to grow organically for over ten years without any segmentation strategy, and therefore, the systems at the head office, branch office, Wi-Fi guests, and POS equipment mostly reside in the same flat network. Therefore, a guest's device connecting to the Wi-Fi in the branch or a compromised branch computer has direct access to the core banking system. Access control lists are the most cost-effective method to create these barriers using equipment that the bank already has, prior to any firewall purchase, as well as embodying the least privilege concept of the multi-layer security strategy.

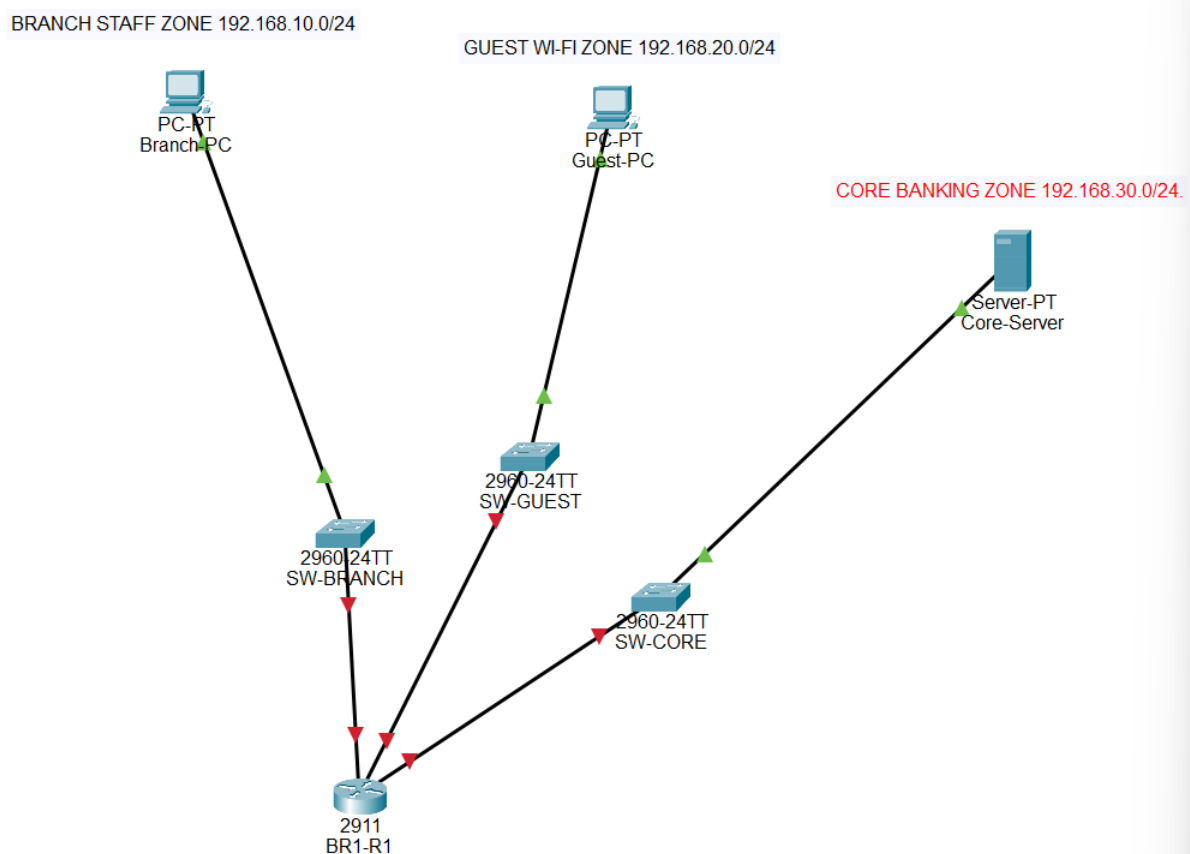


Figure 4.10: Three-zone topology used for the ACL configuration

Router interface addressing:

```
enable
configure terminal
```

```

interface gigabitEthernet 0/0

  description BRANCH-STAFF-ZONE

  ip address 192.168.10.1 255.255.255.0

  no shutdown

  exit

interface gigabitEthernet 0/1

  description GUEST-WIFI-ZONE

  ip address 192.168.20.1 255.255.255.0

  no shutdown

  exit

interface gigabitEthernet 0/2

  description CORE-BANKING-ZONE

  ip address 192.168.30.1 255.255.255.0

  no shutdown

  exit

```

Access control list configuration:

```

ip access-list extended GUEST-IN

  deny ip 192.168.20.0 0.0.0.255 192.168.30.0 0.0.0.255

  deny ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255

  permit ip any any

  exit

ip access-list extended BRANCH-TO-CORE

  permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 443

  permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 22

  deny ip any 192.168.30.0 0.0.0.255

  permit ip any any

  exit

interface gigabitEthernet 0/1

```

```

ip access-group GUEST-IN in

exit

interface gigabitEthernet 0/0

ip access-group BRANCH-TO-CORE in

exit

end

write memory

```

```

%LINEPROTO-5-UPDOWN: Line protocol on Interface GigabitEthernet0/2, changed state to up
exit
Router(config)#ip access-list extended GUEST-IN
Router(config-ext-nacl)#deny ip 192.168.20.0 0.0.0.255 192.168.30.0 0.0.0.255
Router(config-ext-nacl)#deny ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255
Router(config-ext-nacl)#permit ip any any
Router(config-ext-nacl)#exit
Router(config)#ip access-list extended BRANCH-TO-CORE
Router(config-ext-nacl)#permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 443
Router(config-ext-nacl)#permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 22
Router(config-ext-nacl)#deny ip any 192.168.30.0 0.0.0.255
Router(config-ext-nacl)#permit ip any any
Router(config-ext-nacl)#exit
Router(config)#interface gigabitEthernet 0/1
Router(config-if)#ip access-group GUEST-IN in
Router(config-if)#exit
Router(config)#interface gigabitEthernet 0/0
Router(config-if)# ip access-group BRANCH-TO-CORE in
Router(config-if)#exit
Router(config)#end
Router#
%SYS-5-CONFIG_I: Configured from console by console
write memory
Building configuration...
[OK]
Router#

```

Figure 4.11: Extended ACL configuration commands

```

Router(config)#ip access-list extended GUEST-IN
Router(config-ext-nacl)#deny ip 192.168.20.0 0.0.0.255 192.168.30.0 0.0.0.255
Router(config-ext-nacl)#deny ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255
Router(config-ext-nacl)#permit ip any any
Router(config-ext-nacl)#exit
Router(config)#ip access-list extended BRANCH-TO-CORE
Router(config-ext-nacl)#permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 443
Router(config-ext-nacl)#permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 22
Router(config-ext-nacl)#deny ip any 192.168.30.0 0.0.0.255
Router(config-ext-nacl)#permit ip any any
Router(config-ext-nacl)#exit
Router(config)#interface gigabitEthernet 0/1
Router(config-if)#ip access-group GUEST-IN in
Router(config-if)#exit
Router(config)#interface gigabitEthernet 0/0
Router(config-if)# ip access-group BRANCH-TO-CORE in
Router(config-if)#exit
Router(config)#end
Router#
%SYS-5-CONFIG_I: Configured from console by console
write memory
Building configuration...
[OK]

```

Figure 4.12: Applying the access lists to the zone interfaces

Verification commands:

```
show access-lists

show ip interface gigabitEthernet 0/1

show ip interface gigabitEthernet 0/0

show running-config

Router>enable
Router#show access-lists
Extended IP access list GUEST-IN
 10 deny ip 192.168.20.0 0.0.0.255 192.168.30.0 0.0.0.255
 20 deny ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255
 30 permit ip any any
Extended IP access list BRANCH-TO-CORE
 10 permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 443
 20 permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 22
 30 deny ip any 192.168.30.0 0.0.0.255
 40 permit ip any any
```

Figure 4.13: Verification of the configured access lists

```
Router#show ip interface gigabitEthernet 0/1
GigabitEthernet0/1 is up, line protocol is up (connected)
 Internet address is 192.168.20.1/24
 Broadcast address is 255.255.255.255
 Address determined by setup command
 MTU is 1500 bytes
 Helper address is not set
 Directed broadcast forwarding is disabled
 Outgoing access list is not set
 Inbound access list is GUEST-IN
 Proxy ARP is enabled
 Security level is default
 Split horizon is enabled
 ICMP redirects are always sent
 ICMP unreachable are always sent
 ICMP mask replies are never sent
 IP fast switching is disabled
 IP fast switching on the same interface is disabled
 IP Flow switching is disabled
 IP Fast switching turbo vector
 IP multicast fast switching is disabled
 IP multicast distributed fast switching is disabled
 Router Discovery is disabled
 --More--
```

Figure 4.14: Verification that the ACL is applied to the guest interface

Control validation - simulated unauthorized access attempts:

```
C:\>ping 192.168.30.10

Pinging 192.168.30.10 with 32 bytes of data:

Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.

Ping statistics for 192.168.30.10:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>
```

Figure 4.15: Guest zone denied access to the core banking zone

```

C:\>ping 192.168.10.10

Pinging 192.168.10.10 with 32 bytes of data:

Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.

Ping statistics for 192.168.10.10:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>

```

Figure 4.16: Guest zone denied access to the branch staff zone

```

C:\>ping 192.168.30.10

Pinging 192.168.30.10 with 32 bytes of data:

Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.
Reply from 192.168.20.1: Destination host unreachable.

Ping statistics for 192.168.30.10:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>

```

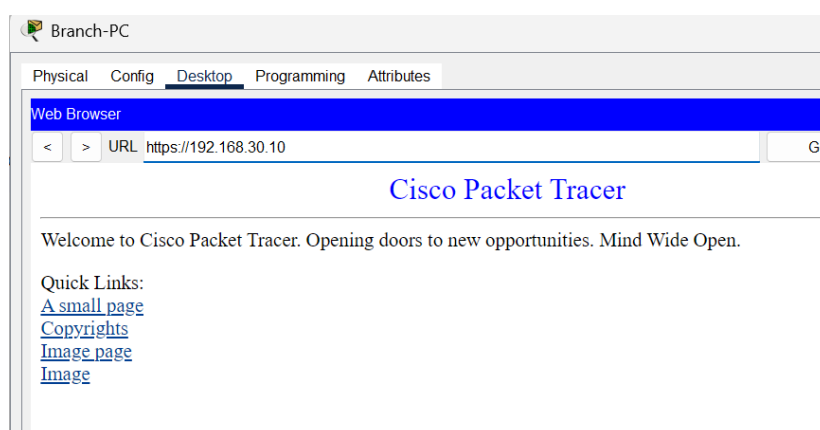


Figure 4.17: Branch staff permitted only the required application port

```

Router#show access-lists
Extended IP access list GUEST-IN
 10 deny ip 192.168.20.0 0.0.0.255 192.168.30.0 0.0.0.255 (8 match(es))
 20 deny ip 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255 (4 match(es))
 30 permit ip any any
Extended IP access list BRANCH-TO-CORE
 10 permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 443 (5 match(es))
 20 permit tcp 192.168.10.0 0.0.0.255 host 192.168.30.10 eq 22
 30 deny ip any 192.168.30.0 0.0.0.255
 40 permit ip any any

```

Figure 4.18: Match counters confirming the deny rules were enforced

Expected verification results include access-lists displaying all the named access lists along with their statements in the proper sequence as well as show ip interface confirming the application of the lists in the inbound direction on the appropriate interfaces. The guest

workstation should not be able to connect to any of the two internal zones while being able to access whatever is external to these two, and thus the denial statements are particular in nature and not universal. The branch workstation should not be able to ping the core banking server but should be able to access the banking application using HTTPS, and hence the principle of least privilege applies here.

Member 4 - IT24102328 – Wickrama Edirisooriya A.A.G.

Configuration 01(Plan-Linked): Dynamic ARP Inspection (DAI)

Purpose: DAI prevents ARP spoofing on the flat layer 2 network. It validates ARP packets on untrusted ports against the DHCP Snooping binding table and drops any packet with a mismatched IP-to-MAC mapping.

Threat Addressed: Implements Control [X] from the layered security plan. Directly addresses Threat 2 (Unauthorized physical access to critical IT infrastructure) and supports Threat 1 (Data breach through outdated/unpatched systems).

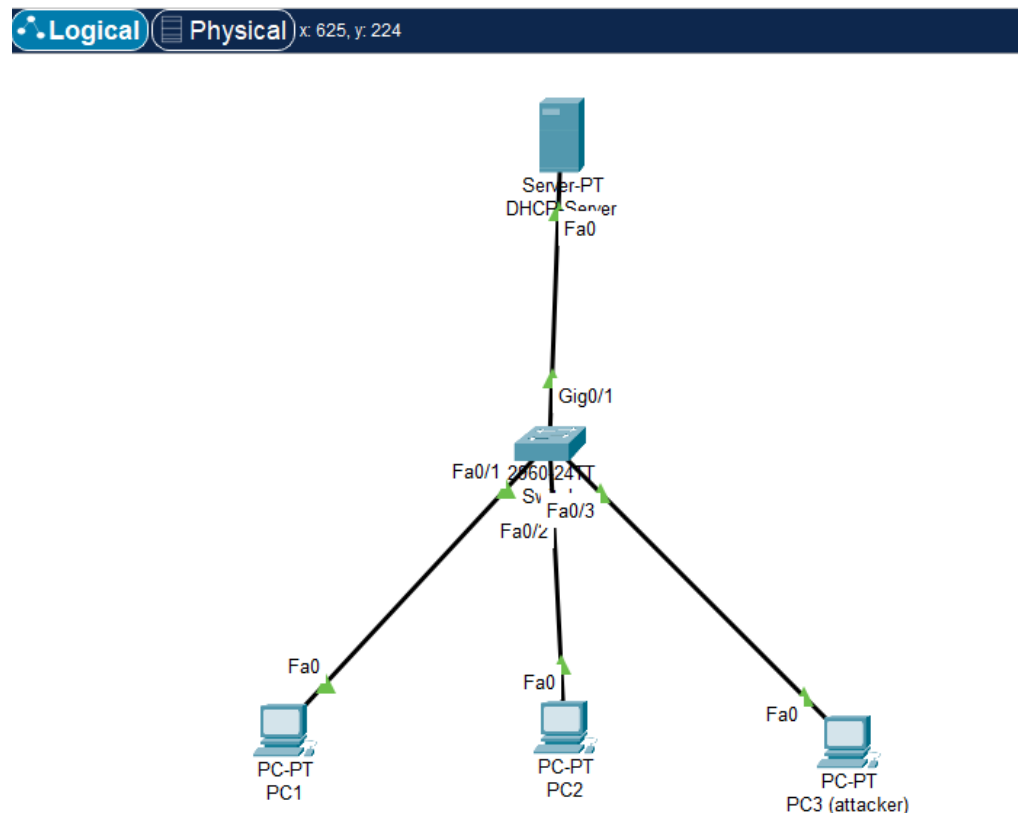


Figure 4.1: DAI Topology

SERVICES

- HTTP
- DHCP**
- DHCPv6
- TFTP
- DNS
- SYSLOG
- AAA
- NTP
- EMAIL
- FTP
- IoT
- VM Management
- Radius EAP

DHCP

Interface: FastEthernet0 Service: ☒ On ☐ Off

Pool Name: serverPool

Default Gateway: 192.168.1.1

DNS Server: 192.168.1.1

Start IP Address: 192.168.1.10

Subnet Mask: 255.255.255.0

Maximum Number of Users: 100

TFTP Server: 0.0.0.0

WLC Address: 0.0.0.0

Buttons: Add Save Remove

Pool Name	Default Gateway	DNS Server	Start IP Address	Subnet Mask	Max User	TFTP Server	WLC Address
serverPool	192.168.1.1	192.168.1.1	192.168.1.10	255.255.255.0	100	0.0.0.0	0.0.0.0

Figure 4.2: DHCP Server FastEthernet0 with IP 192.168.1.1 (DHCP Server Pool Config)

PC1

Physical Config **Desktop** Programming Attributes

IP Configuration X

Interface: FastEthernet0

IP Configuration

☒ DHCP ☐ Static DHCP request successful.

IPv4 Address: 192.168.1.10

Subnet Mask: 255.255.255.0

Default Gateway: 192.168.1.1

DNS Server: 192.168.1.1

IPv6 Configuration

☐ Automatic ☒ Static

IPv6 Address: /

Link Local Address: FE80::230:F2FF:FE58:3C58

Default Gateway:

DNS Server:

802.1X

☐ Use 802.1X Security

Authentication: MD5

Username:

Password:

Figure 4.3: PC1 obtaining IP via DHCP

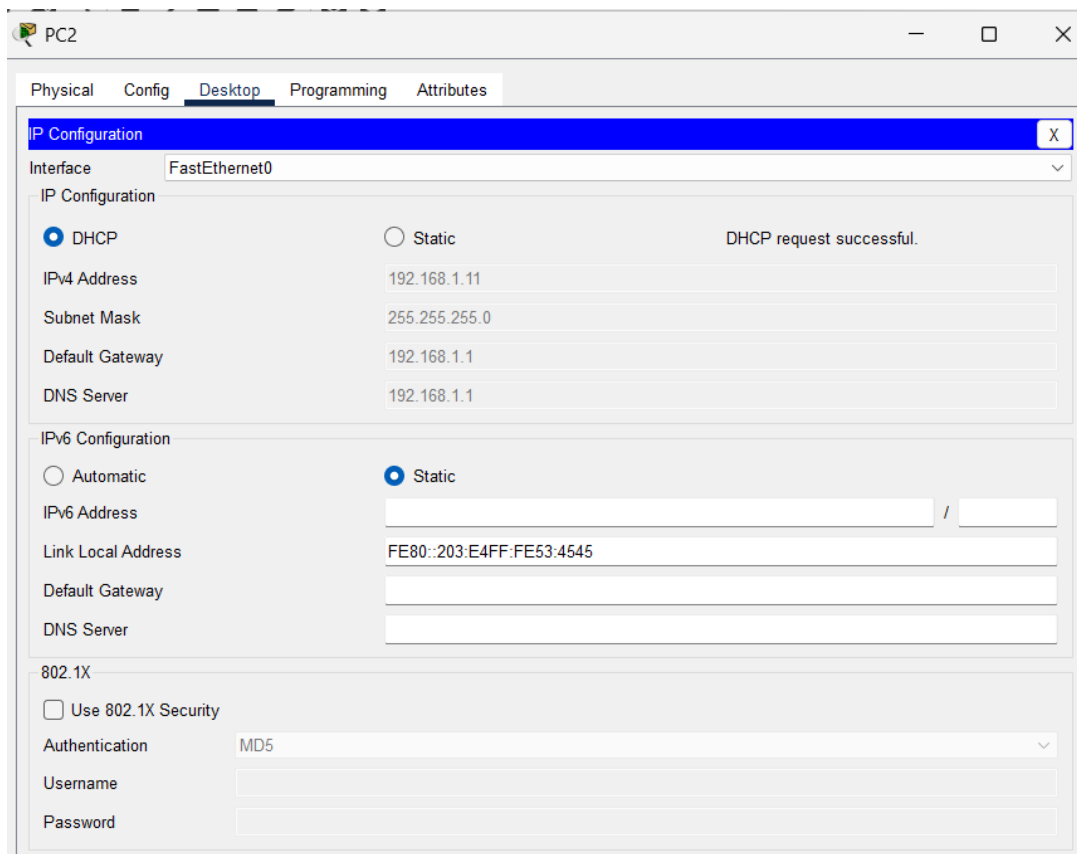


Figure 4.3b: PC2 DHCP

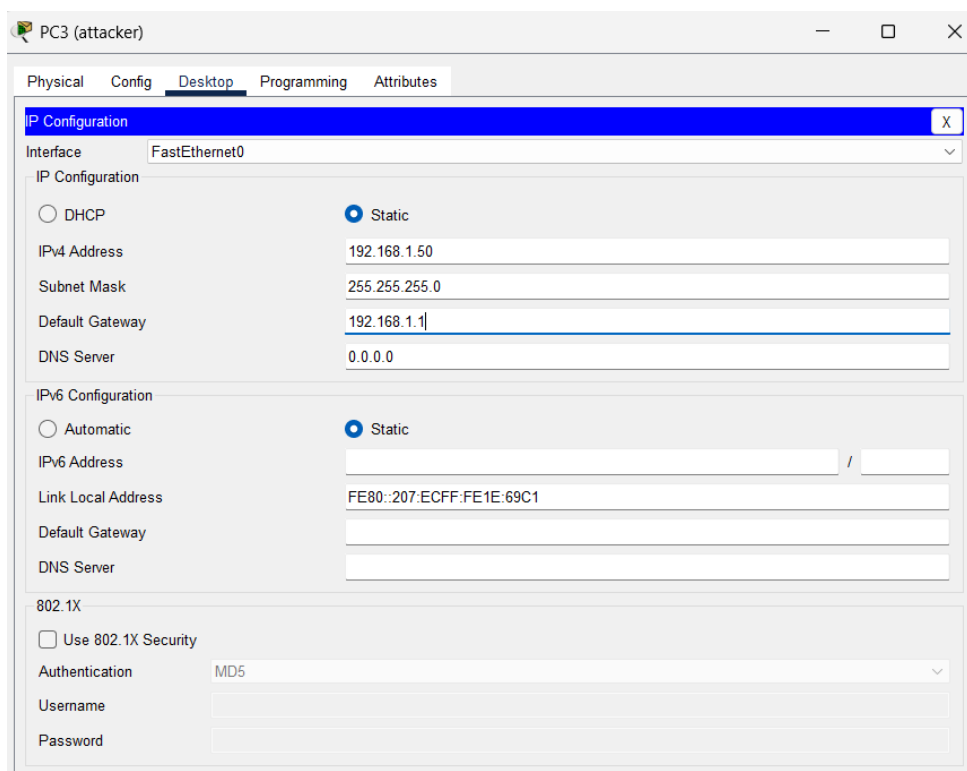


Figure 4.3c: attacker static IP

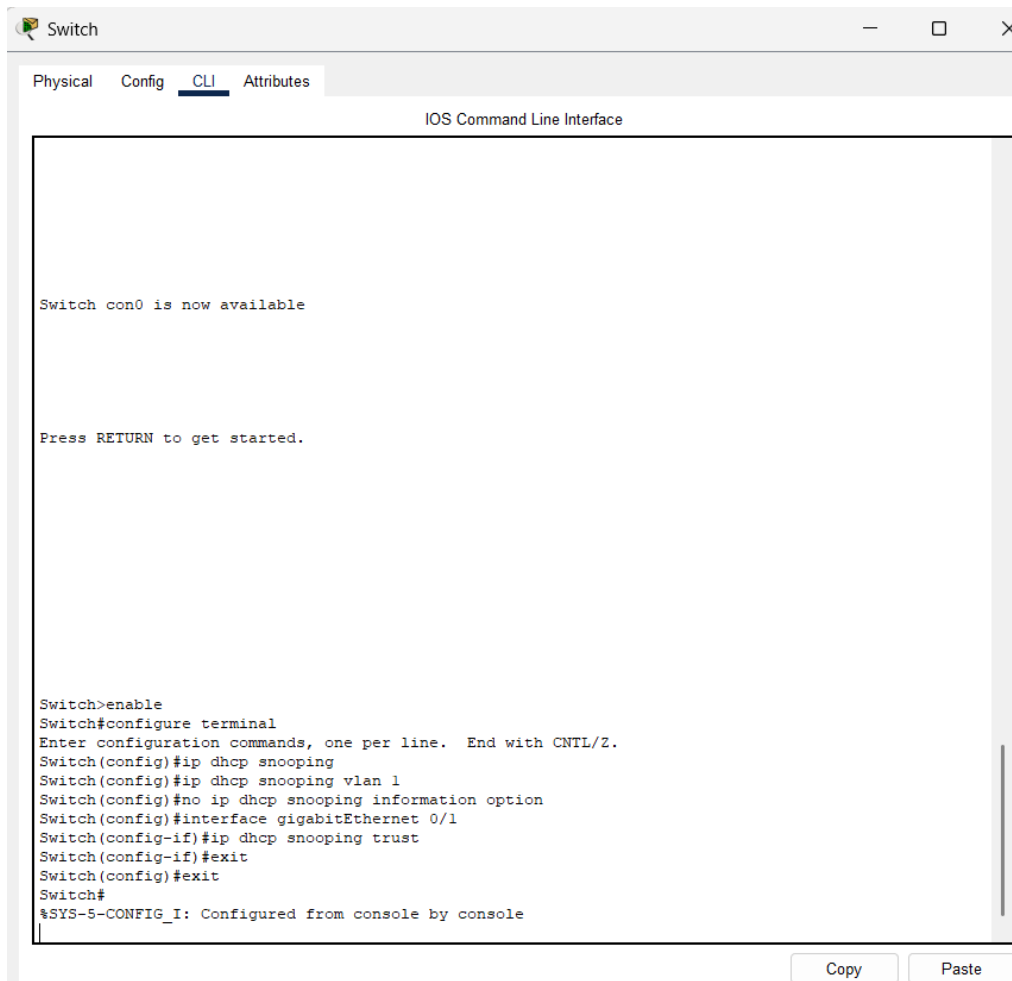


Figure 4.4: DHCP Snooping Configuration

enable

configure terminal

ip dhcp snooping

ip dhcp snooping vlan1

no ip dhcp snooping information option

interface gigabitEthernet 0/1

ip dhcp snooping trust

exit

exit

```
Switch#show ip dhcp snooping
Switch DHCP snooping is enabled
DHCP snooping is configured on following VLANs:
1
Insertion of option 82 is disabled
Option 82 on untrusted port is not allowed
Verification of hwaddr field is enabled
Interface                Trusted      Rate limit (pps)
-----
FastEthernet0/1          no         unlimited
FastEthernet0/2          no         unlimited
GigabitEthernet0/1       yes         unlimited
Switch#
```

Figure 4.5: DHCP Snooping verify

show ip dhcp snooping

```
Switch#show ip dhcp snooping binding
MacAddress                IPAddress      Lease(sec)  Type           VLAN  Interface
-----
00:30:F2:58:3C:58         192.168.1.10  86400       dhcp-snooping  1     FastEthernet0/1
00:03:E4:53:45:45         192.168.1.11  86400       dhcp-snooping  1     FastEthernet0/2
Total number of bindings: 2
Switch#
```

Figure 4.6: DHCP Binding Table

show ip dhcp snooping binding

```
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#ip arp inspection vlan 1
Switch(config)#interface gigabitEthernet 0/1
Switch(config-if)#ip arp inspection trust
Switch(config-if)#exit
Switch(config)#exit
Switch#
%SYS-5-CONFIG_I: Configured from console by console
```

Figure 4.7: DAI Configuration

configure terminal

ip arp inspection vlan 1

interface gigabitEthernet 0/1

ip arp inspection trust

exit

exit

```
Switch#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Switch(config)#ip arp inspection validate src-mac dst-mac ip
Switch(config)#exit
Switch#
%SYS-5-CONFIG_I: Configured from console by console
```

Figure 4.8: DAI Validate

configure terminal

ip arp inspection validate src-mac dst-mac ip

exit

```
show ip arp inspection vlan 1

Source Mac Validation      : Enabled
Destination Mac Validation : Enabled
IP Address Validation      : Enabled

Vlan    Configuration    Operation    ACL Match    Static ACL
----    -
1       Enabled          Active

Vlan    ACL Logging      DHCP Logging    Probe Logging
----    -
1       Deny             Deny            Off

Switch#
```

Figure 4.9: DAI Verify

show ip arp inspection vlan 1

```
Switch#show ip arp inspection interfaces

Interface    Trust State    Rate (pps)    Burst Interval
-----
Fa0/1        Untrusted      15            1
Fa0/2        Untrusted      15            1
Fa0/3        Untrusted      15            1
Fa0/4        Untrusted      15            1
Fa0/5        Untrusted      15            1
Fa0/6        Untrusted      15            1
Fa0/7        Untrusted      15            1
Fa0/8        Untrusted      15            1
Fa0/9        Untrusted      15            1
Fa0/10       Untrusted      15            1
Fa0/11       Untrusted      15            1
Fa0/12       Untrusted      15            1
Fa0/13       Untrusted      15            1
Fa0/14       Untrusted      15            1
Fa0/15       Untrusted      15            1
Fa0/16       Untrusted      15            1
Fa0/17       Untrusted      15            1
Fa0/18       Untrusted      15            1
Fa0/19       Untrusted      15            1
Fa0/20       Untrusted      15            1
Fa0/21       Untrusted      15            1
Fa0/22       Untrusted      15            1
Fa0/23       Untrusted      15            1
Fa0/24       Untrusted      15            1
Gig0/1       Trusted        15            1
Gig0/2       Untrusted      15            1
Switch#
Switch#
```

Figure 4.10: DAI Interfaces

show ip arp inspection interfaces

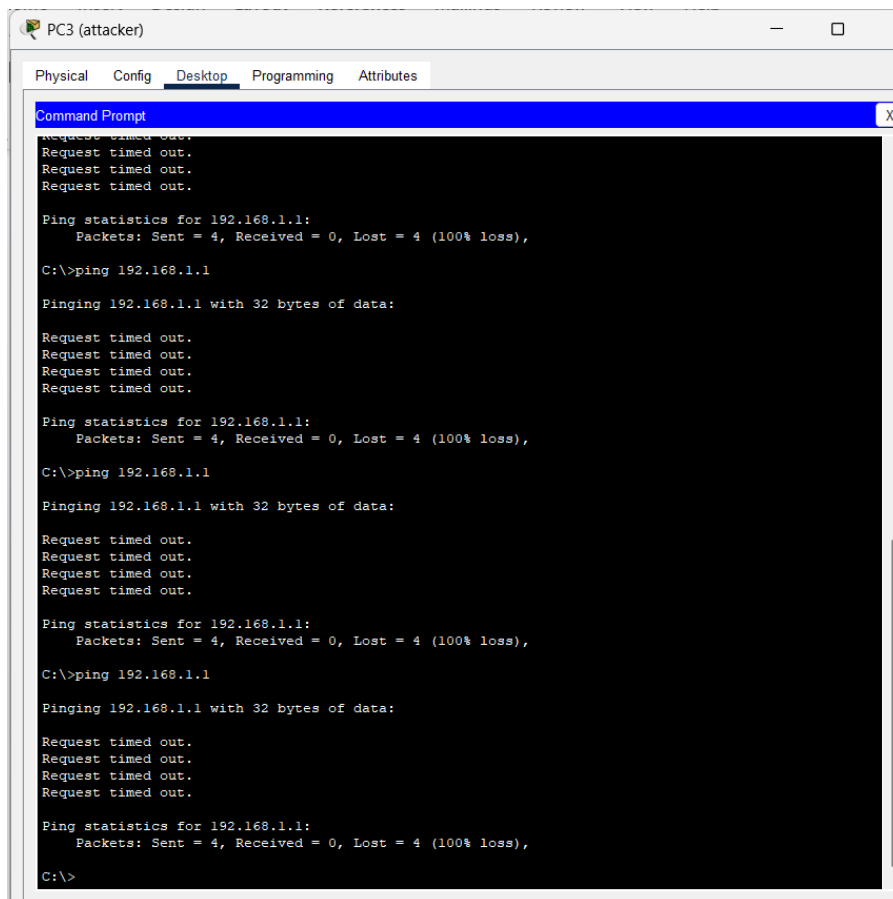


Figure 4.11: Generate ARP traffic from attacker(attacker's 5pings showing 100% loss)

ping 192.168.1.1

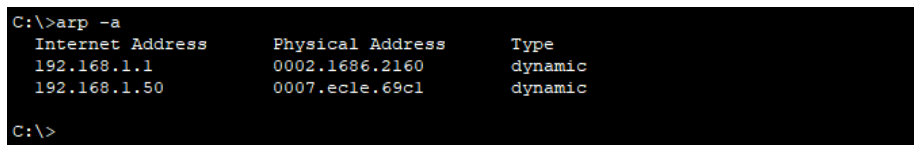


Figure 4.12: PC1 arp -a with gateway entry

arp -a

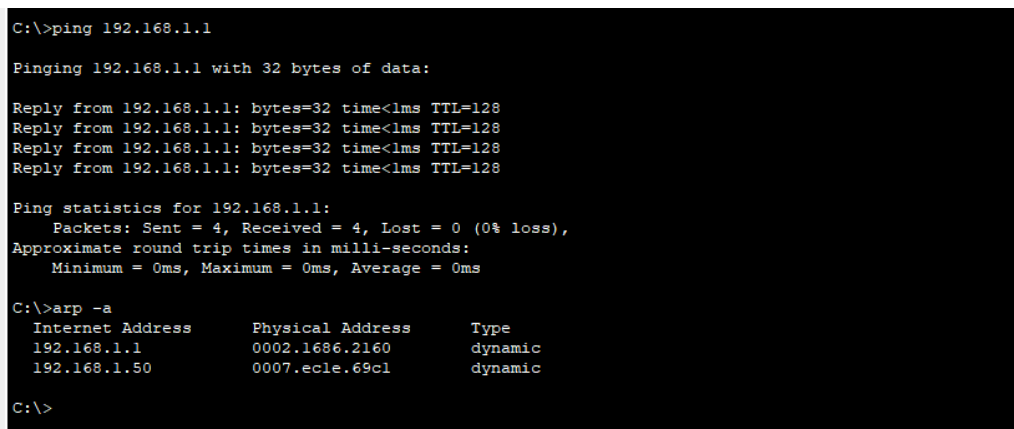


Figure 4.13: PC1 ping success 0% loss

Configuration 02(Free Choice): Zone-Based Policy Firewall (ZPF)

Purpose: ZPF replaces the flat network with explicit security zones. Traffic between zones is denied by default unless a policy explicitly permits it. This prevents a compromised branch workstation from reaching core banking systems.

Real-World Problem Solved: Northbridge's network has no segmentation — head office, branch, guest Wi-Fi, and PoS equipment share one flat network. A single compromised branch workstation can spread ransomware directly to core banking systems. ZPF creates a security boundary so that only explicitly permitted traffic can cross zones.

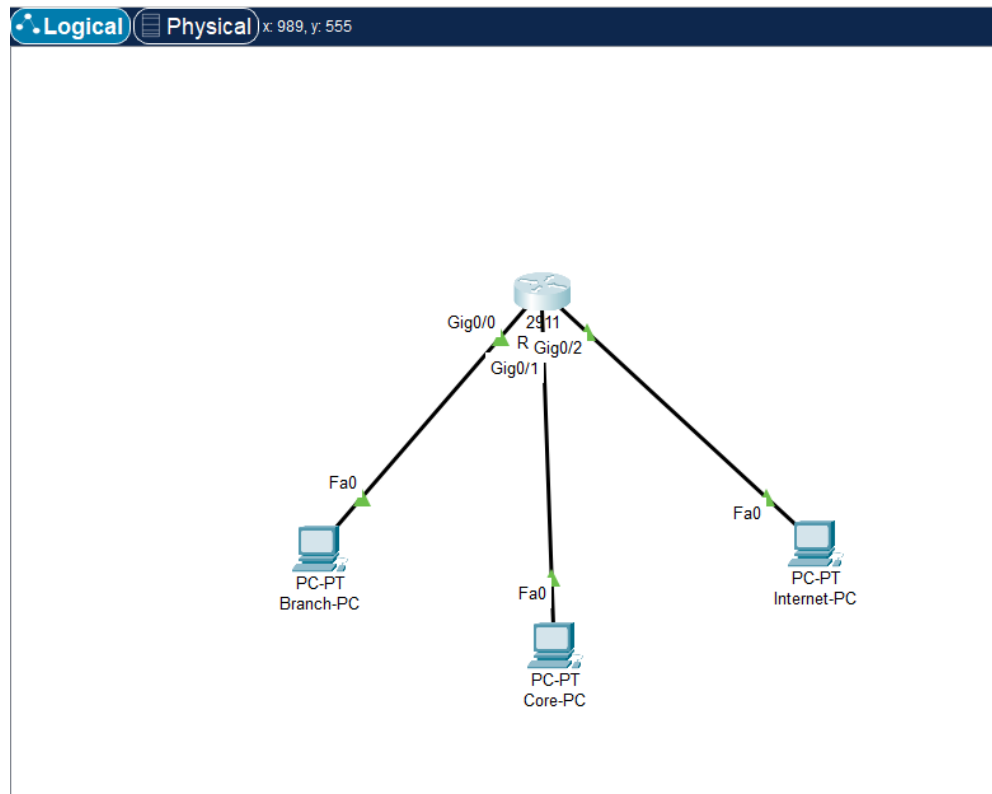


Figure 4.14: ZPF Topology

Branch-PC

Physical Config **Desktop** Programming Attributes

IP Configuration [X]

Interface: FastEthernet0

IP Configuration

☐ DHCP ☒ Static

IPv4 Address: 192.168.10.10

Subnet Mask: 255.255.255.0

Default Gateway: 192.168.10.1

DNS Server: 0.0.0.0

IPv6 Configuration

☐ Automatic ☒ Static

IPv6 Address: /

Link Local Address: FE80::201:64FF:FE96:C756

Default Gateway:

DNS Server:

802.1X

☐ Use 802.1X Security

Authentication: MD5

Username:

Password:

Figure 4.15a: configure branch PC

Core-PC

Physical Config **Desktop** Programming Attributes

IP Configuration [X]

Interface: FastEthernet0

IP Configuration

☐ DHCP ☒ Static

IPv4 Address: 192.168.20.10

Subnet Mask: 255.255.255.0

Default Gateway: 192.168.20.1

DNS Server: 0.0.0.0

IPv6 Configuration

☐ Automatic ☒ Static

IPv6 Address: /

Link Local Address: FE80::250:FFF:FE51:D992

Default Gateway:

DNS Server:

802.1X

☐ Use 802.1X Security

Authentication: MD5

Username:

Password:

Figure 4.15b: configure core PC

The screenshot shows the 'Internet-PC' configuration window with the 'Desktop' tab selected. The 'IP Configuration' section is active, showing settings for the 'FastEthernet0' interface. The 'Static' radio button is selected for both IPv4 and IPv6 configurations. The IPv4 settings are: IP Address 203.0.113.10, Subnet Mask 255.255.255.0, Default Gateway 203.0.113.1, and DNS Server 0.0.0.0. The IPv6 settings are: Static selected, Link Local Address FE80::260:5CFF:FE78:4D81, and empty fields for IPv6 Address, Default Gateway, and DNS Server. The '802.1X' section has 'Use 802.1X Security' unchecked, 'Authentication' set to 'MD5', and empty fields for Username and Password.

IP Configuration	
Interface	FastEthernet0
IP Configuration	
☐ DHCP	☒ Static
IPv4 Address	203.0.113.10
Subnet Mask	255.255.255.0
Default Gateway	203.0.113.1
DNS Server	0.0.0.0
IPv6 Configuration	
☐ Automatic	☒ Static
IPv6 Address	
Link Local Address	FE80::260:5CFF:FE78:4D81
Default Gateway	
DNS Server	
802.1X	
☐ Use 802.1X Security	
Authentication	MD5
Username	
Password	

Figure 4.15c: configure internet PC

The screenshot shows the 'Router' configuration window with the 'CLI' tab selected. The 'IOS Command Line Interface' is displayed, showing a series of configuration commands entered in the terminal. The commands configure three gigabitEthernet interfaces (0/0, 0/1, and 0/2) with IP addresses and subnet masks, and disable shutdown. The terminal output shows the configuration is complete and the router is now available.

```

Router con0 is now available

Press RETURN to get started.

Router>enable
Router#configure terminal
Enter configuration commands, one per line. End with CNTRL/Z.
Router(config)#interface gigabitEthernet 0/0
Router(config-if)#ip address 192.168.10.1 255.255.255.0
Router(config-if)#no shutdown
Router(config-if)#exit
Router(config)#interface gigabitEthernet 0/1
Router(config-if)#ip address 192.168.20.1 255.255.255.0
Router(config-if)#no shutdown
Router(config-if)#exit
Router(config)#interface gigabitEthernet 0/2
Router(config-if)#ip address 203.0.113.1 255.255.255.0
Router(config-if)#no shutdown
Router(config-if)#exit
Router(config)#exit
Router#
%SYS-S-CONFIG_I: Configured from console by console
Router#

```

Figure 4.16: router interface config

```

enable

configure terminal

interface gigabitEthernet 0/0

ip address 192.168.10.1 255.255.255.0

no shutdown

exit

interface gigabitEthernet 0/1

ip address 192.168.20.1 255.255.255.0

no shutdown

exit

interface gigabitEthernet 0/2

ip address 203.0.113.1 255.255.255.0

no shutdown

exit

exit

```

```

Router#show ip interface brief

```

Interface	IP-Address	OK?	Method	Status	Protocol
GigabitEthernet0/0	192.168.10.1	YES	manual	up	up
GigabitEthernet0/1	192.168.20.1	YES	manual	up	up
GigabitEthernet0/2	203.0.113.1	YES	manual	up	up
Vlan1	unassigned	YES	unset	administratively down	down

```

Router#

```

Figure 4.16b: verify interfaces

```
show ip interface brief
```

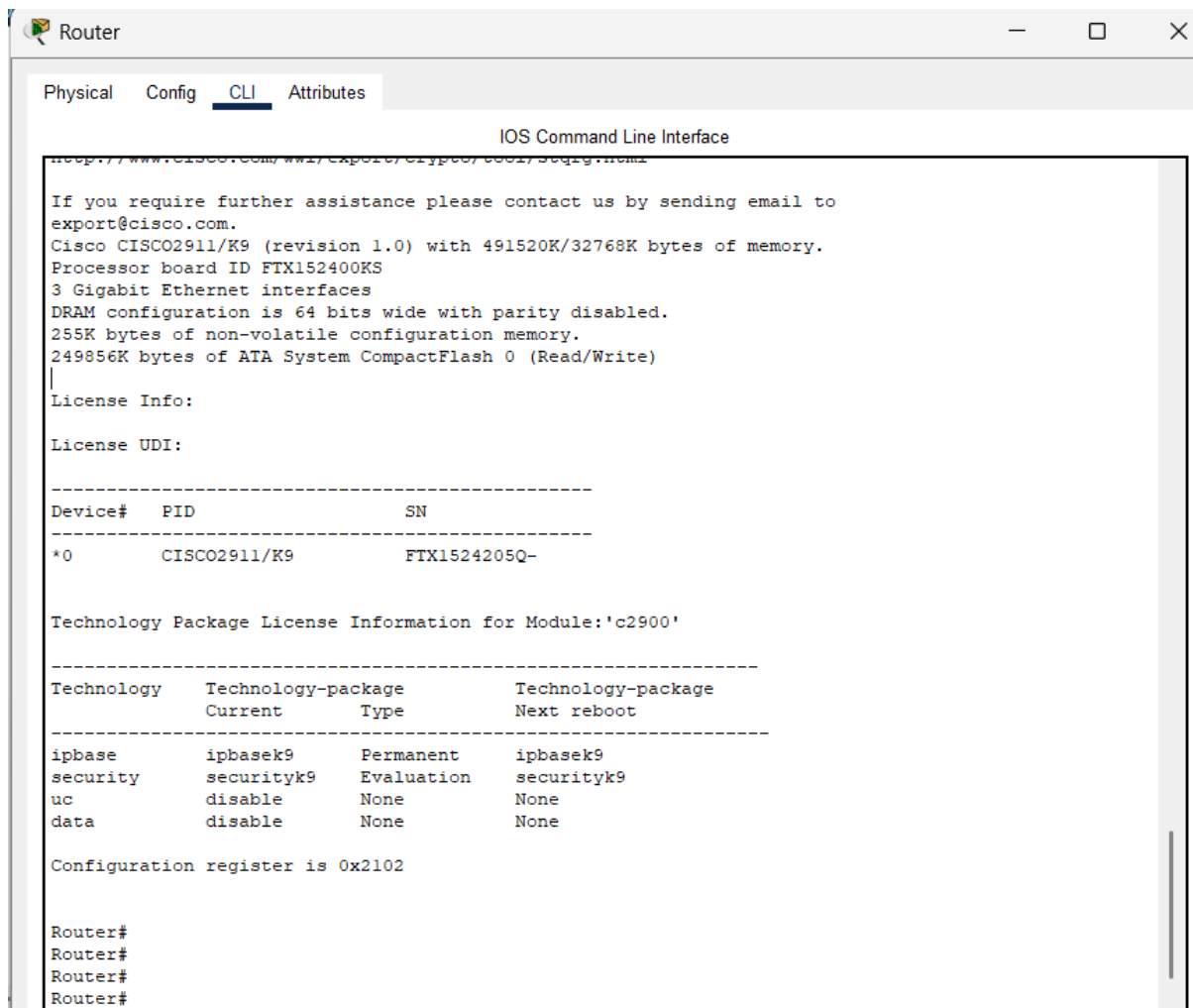


Figure 4.17: security license active

enable

show version

```

Router#
Router#
Router#
Router#enable
Router#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#zone security BRANCH-ZONE
Router(config-sec-zone)#zone security CORE-ZONE
Router(config-sec-zone)#zone security INTERNET-ZONE
Router(config-sec-zone)#exit
Router(config)#

```

Figure 4.18: zones created

enable

configure terminal

zone security BRANCH-ZONE

zone security CORE-ZONE

zone security INTERNET-ZONE

exit

```
Router#show zone security
zone self
  Description: System defined zone
```

```
zone BRANCH-ZONE
```

```
zone CORE-ZONE
```

```
zone INTERNET-ZONE
```

```
Router#
```

Figure 4.18b: verify zones

show zone security

```
Router#enable
Router#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#access-list 100 permit tcp 192.168.10.0 0.0.0.255 host 192.168.20.10 eq 443
Router(config)#access-list 101 permit ip 192.168.10.0 0.0.0.255 any
Router(config)#exit
Router#
%SYS-5-CONFIG_I: Configured from console by console
```

Figure 4.19: ACLs

enable

configure terminal

access-list 100 permit tcp 192.168.10.0 0.0.0.255 host 192.168.20.10 eq 443

access-list 101 permit ip 192.168.10.0 0.0.0.255 any

exit

```
Router#
%SYS-5-CONFIG_I: Configured from console by console
show access-lists
Extended IP access list 100
  10 permit tcp 192.168.10.0 0.0.0.255 host 192.168.20.10 eq 443
Extended IP access list 101
  10 permit ip 192.168.10.0 0.0.0.255 any
Router#
```

Figure 4.19b: Verify ACLs

show access-lists

```

Router#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#class-map type inspect match-all BRANCH-TO-CORE-CLASS
Router(config-cmap)#match access-group 100
Router(config-cmap)#exit
Router(config)#class-map type inspect match-all BRANCH-TO-INTERNET-CLASS
Router(config-cmap)#match access-group 101
Router(config-cmap)#exit
Router(config)#exit
Router#
%SYS-5-CONFIG_I: Configured from console by console

```

Figure 4.20: class-maps

configure terminal

class-map type inspect match-all BRANCH-TO-CORE-CLASS

match access-group 100

exit

class-map type inspect match-all BRANCH-TO-INTERNET-CLASS

match access-group 101

exit

exit

```

Router#show running-config | section class-map
class-map type inspect match-all BRANCH-TO-CORE-CLASS
  match access-group 100
class-map type inspect match-all BRANCH-TO-INTERNET-CLASS
  match access-group 101
Router#

```

Figure 4.20b: verify class-maps

Show running-config | section class-map

```

Router#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#policy-map type inspect BRANCH-TO-CORE-POLICY
Router(config-pmap)#class type inspect BRANCH-TO-CORE-CLASS
Router(config-pmap-c)#inspect
%No specific protocol configured in class BRANCH-TO-CORE-CLASS for inspection. All protocols will
be inspected
Router(config-pmap-c)#exit
Router(config-pmap)#exit
Router(config)#policy-map type inspect BRANCH-TO-INTERNET-POLICY
Router(config-pmap)#class type inspect BRANCH-TO-INTERNET-CLASS
Router(config-pmap-c)#inspect
%No specific protocol configured in class BRANCH-TO-INTERNET-CLASS for inspection. All protocols
will be inspected
Router(config-pmap-c)#exit
Router(config-pmap)#exit
Router(config)#exit
Router#
%SYS-5-CONFIG_I: Configured from console by console

```

Figure 4.21: create both policy-maps

```

configure terminal

policy-map type inspect BRANCH-TO-CORE-POLICY

class type inspect BRANCH-TO-CORE-CLASS

inspect

exit

exit

policy-map type inspect BRANCH-TO-INTERNET-POLICY

class type inspect BRANCH-TO-INTERNET-CLASS

inspect

exit

exit

exit

```

```

Router>enable
Router#show running-config | section policy-map
policy-map type inspect BRANCH-TO-CORE-POLICY
  class type inspect BRANCH-TO-CORE-CLASS
  inspect
policy-map type inspect BRANCH-TO-INTERNET-POLICY
  class type inspect BRANCH-TO-INTERNET-CLASS
  inspect
Router#

```

Figure 4.21b: verify policy maps

```

enable

show running-config | section policy-map

```

```

Router#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#zone-pair security BRANCH-TO-CORE source BRANCH-ZONE destination CORE-ZONE
Router(config-sec-zone-pair)#service-policy type inspect BRANCH-TO-CORE-POLICY
Router(config-sec-zone-pair)#exit
Router(config)#zone-pair security BRANCH-TO-INTERNET source BRANCH-ZONE destination INTERNET-ZONE
Router(config-sec-zone-pair)#service-policy type inspect BRANCH-TO-INTERNET-POLICY
Router(config-sec-zone-pair)#exit
Router(config)#exit
Router#
%SYS-5-CONFIG_I: Configured from console by console
|

```

Figure 4.22: zone-pairs

```

configure terminal

zone-pair security BRANCH-TO-CORE source BRANCH-ZONE destination CORE-ZONE

```

```
service-policy type inspect BRANCH-TO-CORE-POLICY
```

```
exit
```

```
zone-pair security BRANCH-TO-INTERNET source BRANCH-ZONE destination  
INTERNET-ZONE
```

```
service-policy type inspect BRANCH-TO-INTERNET-POLICY
```

```
exit
```

```
exit
```

```
show zone-pair security  
Zone-pair name BRANCH-TO-CORE  
  Source-Zone BRANCH-ZONE Destination-Zone CORE-ZONE  
  service-policy BRANCH-TO-CORE-POLICY  
  
Zone-pair name BRANCH-TO-INTERNET  
  Source-Zone BRANCH-ZONE Destination-Zone INTERNET-ZONE  
  service-policy BRANCH-TO-INTERNET-POLICY  
Router#
```

Figure 4.22b: verify zone pairs

```
show zone-pair security
```

```
Router#configure terminal  
Enter configuration commands, one per line. End with CNTL/Z.  
Router(config)#interface gigabitEthernet 0/0  
Router(config-if)#zone-member security BRANCH-ZONE  
Router(config-if)#exit  
Router(config)#interface gigabitEthernet 0/1  
Router(config-if)#zone-member security CORE-ZONE  
Router(config-if)#exit  
Router(config)#interface gigabitEthernet 0/2  
Router(config-if)#zone-member security INTERNET-ZONE  
Router(config-if)#exit  
Router(config)#exit  
Router#  
%SYS-5-CONFIG_I: Configured from console by console
```

Figure 4.23: interface zone membership

```
configure terminal
```

```
interface gigabitEthernet 0/0
```

```
zone-member security BRANCH-ZONE
```

```
exit
```

```
interface gigabitEthernet 0/1
```

```
zone-member security CORE-ZONE
```

```
exit
```

```
interface gigabitEthernet 0/2
```

```
zone-member security INTERNET-ZONE
```

```
exit
```

```
exit
```

```
Router#show zone security
zone self
  Description: System defined zone
```

```
zone BRANCH-ZONE
  Member Interfaces:
    GigabitEthernet0/0
```

```
zone CORE-ZONE
  Member Interfaces:
    GigabitEthernet0/1
```

```
zone INTERNET-ZONE
  Member Interfaces:
    GigabitEthernet0/2
```

```
Router#
```

Figure 4.23: verify zone members

```
show zone security
```

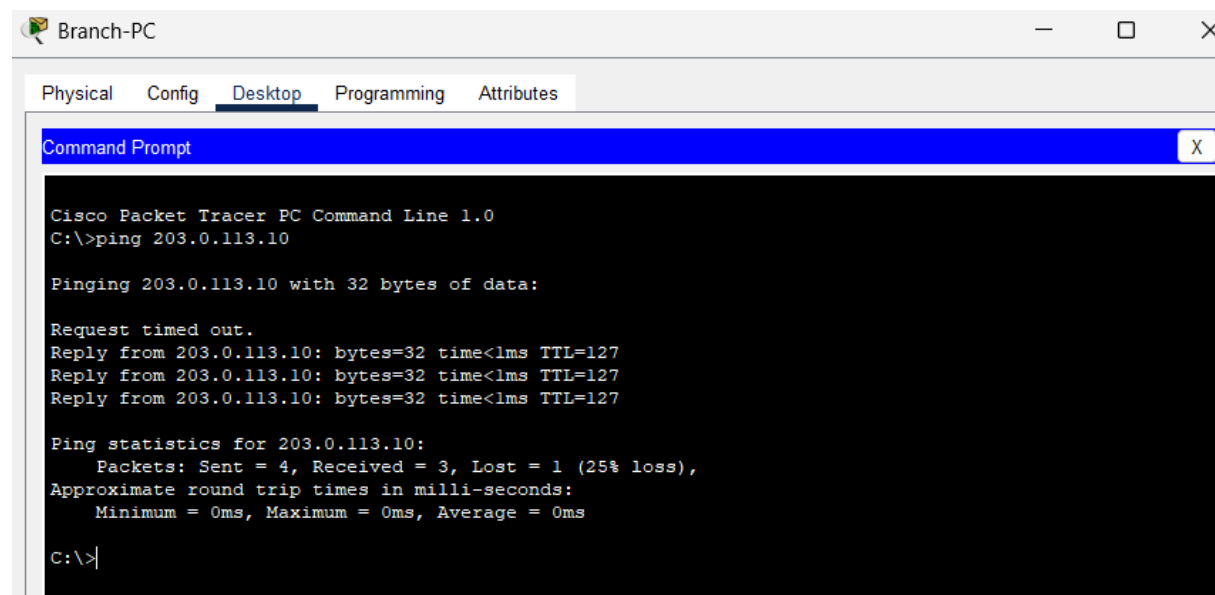


Figure 4.24: branch to internet success

```
ping 203.0.113.10
```

```

C:\>ping 192.168.20.10

Pinging 192.168.20.10 with 32 bytes of data:

Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 192.168.20.10:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>|

```

Figure 4.25: branch to core blocked

ping 192.168.20.10

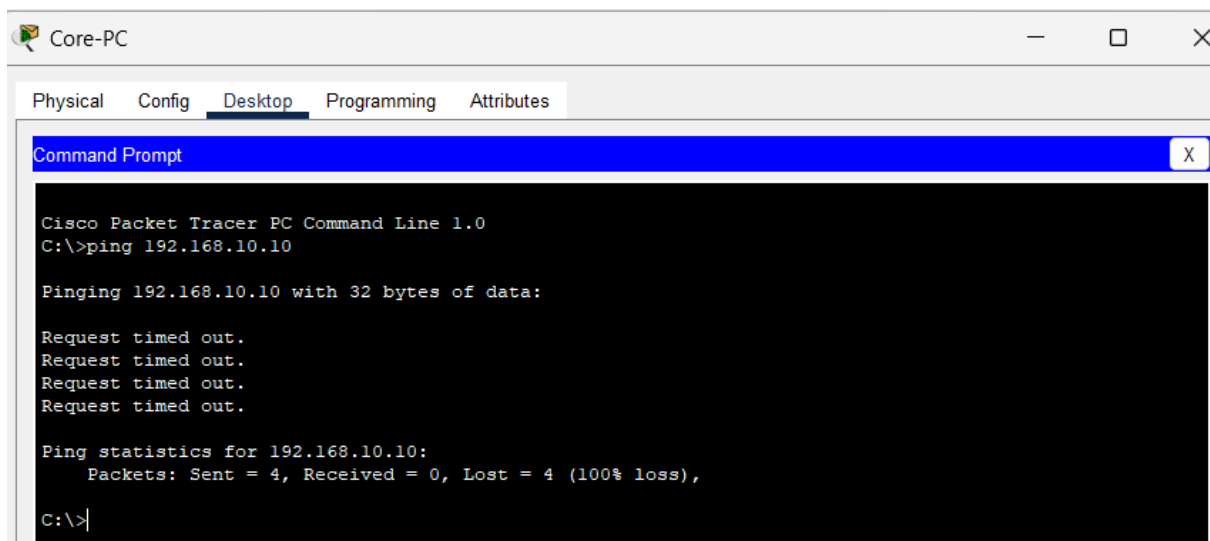


Figure 4.26: core to branch blocked

ping 192.168.10.10

```

C:\>ping 203.0.113.10

Pinging 203.0.113.10 with 32 bytes of data:

Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 203.0.113.10:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),

C:\>|

```

Figure 4.26: core to internet blocked

ping 203.0.113.10

5. Appendices A-D

Individual technology proposals

Member 1 - IT24100139 - Pinthu D.I.U.

VPN Proposal

Recommended solution: Cisco Secure Client + Cisco Secure Firewall using SSL/IKEv2 VPN

Essential Requirements

- Each remote employee and contractor is given a personal username.
- Use a strong password and set up two-factor authentication.
- Stop using the current shared VPN account.

Alternatives Considered

Option	Advantages	Disadvantages for Northbridge	Decision
OpenVPN Access Server	Lower cost; mature; flexible; strong encryption.	Additional administration and less natural integration with the proposed Cisco security stack.	Not selected
WireGuard	Lightweight; high performance; relatively simple architecture.	Enterprise identity/account lifecycle and AAA integration require additional supporting infrastructure.	Not selected

Why Cisco Secure Client Fits Northbridge

Northbridge has remote workers and two external IT contractors who at present share a single VPN account without any individual accountability or multi-factor authentication; individual authentication, logging, and policy enforcement can be achieved using Cisco Secure Client together with centralized AAA.

USER → VPN Gateway → AAA Authentication → MFA → Role-based ACL → Permitted Resource.

AAA Proposal

Recommended solution: Cisco Identity Services Engine (Cisco ISE)

- RADIUS should be used for granting user and network access.
- Where appropriate, use TACACS+ for the administration of network devices

Alternatives Considered

Option	Advantages	Disadvantages	Decision
Windows Network Policy Server (NPS)	Integrates well with Active Directory; relatively inexpensive in Microsoft environments.	Less comprehensive network-access policy functionality than ISE.	Not selected
FreeRADIUS	Open source; inexpensive; flexible.	Greater manual administration and fewer integrated enterprise policy/visibility capabilities.	Not selected

Why Cisco ISE Fits Northbridge

At present, Northbridge keeps separate local user accounts on devices and applications without using centralised authentication; Cisco ISE offers centralised authentication, authorization, accounting, access policy, logging, and individual accountability. This directly addresses Threat 1.

Secure Network Architecture Proposal

Recommended solution: Multi-Zone Segmented Architecture with Perimeter + Internal Segmentation Firewalls

The architecture includes a number of firewalls and has clearly defined security zones.

- Zone 1 - Internet
- Zone 2 - Public DMZ: online banking portal and other public-facing services
- Zone 3 - Employee network
- Zone 4 - Core banking zone
- Zone 5 - Database zone
- Zone 6 - Third-party payment zone
- Zone 7 - Management network
- Zone 8 - Guest Wi-Fi

- Zone 9 - Remote VPN users

Alternatives Considered

Option	Advantages	Disadvantages / Reason Rejected	Decision
Single Firewall + VLANs	Cheaper; simpler.	A compromise or policy failure at one firewall creates a much larger failure domain for high-value banking systems.	Not selected
Full Microsegmentation / Zero-Trust Architecture	Very granular security; strong lateral-movement protection.	Significantly greater deployment complexity and operational maturity requirements for an organization starting from almost no segmentation.	Not selected

Why This Architecture Fits Northbridge

Currently, Northbridge provides guest Wi-Fi and allows access between the branch systems and the critical systems. The suggested segmented design restricts lateral movement and establishes a dedicated security boundary around the third-party payment integration, which directly addresses Threat 2.

IDS/IPS Proposal

Recommended solution: Cisco Secure Firewall IPS / Snort 3

Carry out IPS inspections at the strategic network boundaries.

Alternatives Considered

Option	Advantages	Disadvantages	Decision
Suricata	Open source; strong IDS/IPS capability; good protocol inspection.	Additional management and integration effort compared with using IPS integrated into the proposed Cisco firewall environment.	Not selected
Zeek	Excellent network visibility; powerful network-security analytics.	Primarily network-security monitoring/analysis rather than a straightforward inline IPS replacement.	Not selected

Why Cisco Secure Firewall IPS / Snort 3 Fits Northbridge

At present, Northbridge does not have any intrusion detection system or intrusion prevention system facilities, which means that reconnaissance or active attacks could go undetected until

damage has been done. The use of IPS functionality incorporated into the proposed security firewall will reduce the requirement for separate systems.

Member 2 – IT24101169 – Weligampitiya S.A.S.D.

VPN Solution - Secure Remote Access

Proposed solution: Cisco AnyConnect Secure Mobility Client with SSL/IPSec VPN terminated at head office firewall, per user certificates/credentials and MFA enforced.

Alternative considered: OpenVPN Access Server (open-source/low-cost).

OpenVPN would also be a good, and cheaper, alternative, and solve the “shared account” issue as well. It was rejected due to the fact that Northbridge already required a firewall system upgrade, and running the VPN on the existing firewall (a Cisco ASA/Firepower-class product) would not require them to buy and patch an additional VPN system - since they have no formal patch management process anyway they would find it difficult keeping up with an additional system. AnyConnect works seamlessly with a central AAA server per-user policy.

Northbridge specific justification: The scenario explicitly mentions the existing single shared VPN account shared between the two external contractors and remote staff, with no MFA and no accountability for individual staff at all, this is the same vulnerability as Threat 2 above. This is anyConnect's job, it assigns its own credential per user/contractor, and requires MFA at the connection time, hence closing the gap between them and providing Northbridge with the individual audit trail it doesn't have.

AAA Solution - Centralized Authentication

Proposed solution: Cisco Identity Services Engine (ISE) with RADIUS for network device/VPN authentication as well as TACACS+ for administrative access to network infrastructure.

Alternative considered: to use FreeRADIUS which is an open source RADIUS server.

FreeRADIUS is capable and free, and was seriously considered for a mid-sized bank due to cost considerations. It was rejected because Northbridge required multiple types of access to be covered with ISE at the same time: VPN users, logging into via the branch network, and managing switches/firewalls; the latter two are covered by ISE's native TACACS+ support for admin/device access, rather than RADIUS for user/network access, so that was a cleaner single-platform fit. FreeRADIUS does not support TACACS+ natively, meaning it would be necessary to run two separate open-source systems, rather than one integrated system, which would add the operational complexity of a newly formed security team.

Northbridge specific justification: Scenario: Every device and application contains its own list of user accounts, and separately, password reuse and sharing is seen among the branch staff. The local-account sprawl is removed and a centralized AAA platform provides Northbridge a single location to enforce password policy, MFA, and account lockout in all 6 branches and head office.

Secure Network Architecture - Multiple Firewalls, Defined Zones

Proposed solution: A three zone solution with two tiers of firewall, a perimeter Next-Gen Firewall (NGF) such as Cisco Firepower or Fortinet FortiGate providing a DMZ for the internet facing online banking portal/mobile app and an internal firewall with core banking systems, branch/staff networks, guest Wi-Fi and PoS equipment separated into distinct VLANs/zones.

Alternative considered: Use a single firewall at the Internet edge only, and segment the VLANs by using switch ACLs (no second firewall tier).

This is cheaper and simpler to manage, and was considered given Northbridge's newly formed security team. The decision was made because a threat from a compromised branch device could only be prevented by static rules, not deep packet inspection or integration with intrusion prevention, between zones - therefore, it wasn't really prevented at all. Since the core banking database is Northbridge's most essential resource, it would be worthwhile having a stateful firewall at his own internal flat network between the database and the rest of the flat network.

Northbridge specific justification: This directly addresses the main issue faced by this scenario is that much of the systems in the head office, branch systems, guest Wi-Fi, and point of service support equipment reside within a single flat network space, and the obvious ransomware scenario involves the spread of the ransomware from one compromised branch workstation to the rest of the flat network. This is exactly what would have contained the scenario, with the DMZ corresponding to the fact that the portal/app are directly exposed to the public internet.

IDS/IPS Solution

Solution proposed: Suricata (or a commercial NGFW-integrated IPS module like Cisco Firepower's built-in IPS) deployed in-line at the choke points of the internal firewall, while the signature and anomaly detection is enabled.

Alternative considered: Snort is used as a passive IDS.

Snort is a tried and tested solution which was seriously considered. For Northbridge specifically, the passive/IDS-only deployment was rejected because there is no intrusion detection or intrusion prevention capability anywhere on the network, meaning that the bank would not be able to stop the spread in real time if reconnaissance or an active compromise happened; it would just be reacting after the fact using a detection-only system. The in-line IPS which actively drops malicious traffic between zones was more akin to the speeds of the ransomware attacks that were observed in the region where unsegmented networks were used to propagate the attacks.

Northbridge-specific justification: This is because even if the ransomware makes its way into a branch workstation (as described in the scenario above for a sector-wide ransomware), lateral movement can be stopped and logged at the boundary between the branch/staff zone

and the core banking zone (where the IPS is deployed), thereby addressing the gap of no centralized logging or audit trail across systems at the same time.

Member 3 - IT24102358 - Silva D.P.L.T.D.

VPN Solution - Secure Remote Access

Recommended Solution: Fortinet FortiGate SSL-VPN in tunnel mode using FortiClient software with separate accounts for each of the remote employees and each of the two external contractors, mandatory use of Forti Token two-factor authentication for all connections, and FortiClient endpoint compliance checks which confirm the patched operating system, presence of antivirus software, and encrypted disk drive. Alternative consideration: Wire Guard, self-hosted on a Linux host at head office.

The Wire Guard protocol is speedy, advanced, secure and free, which makes it appealing for the bank that has traditionally spent virtually all its security budget on physical security and not on IT. It was declined due to the fact that the Wire Guard protocol authenticates the devices with the help of their public keys but does not authenticate users by means of their identities; it lacks native MFA features, integration with an authentication platform and endpoint posture assessment capabilities. Providing per-user MFA and endpoint posture assessment services on top of the existing solution would require deploying a number of new components, which is precisely what the Northbridge's security team cannot afford at this stage. Selecting the solution where the identity will be defined by the holder of the key file will tackle only the second part of the issue.

Northbridge specific justification: In the given scenario, Northbridge provides remote work possibilities and allows employees to work using their personal devices and telephones without providing any specific guidelines. This is the weakness on which my threat is based. Per-user accounts and MFA help in bridging the gap in sharing of credentials, but there is nothing mentioned regarding the condition of the device from where the tunnel is being created. Endpoint compliance check is the only control among all those mentioned above which takes into consideration the unmanaged personal laptop and therefore makes this solution preferable than other solutions based on identity management. It also enables Northbridge to have an individual audit trail of the employee, which cannot be obtained at present because of the shared credentials of the remote access.

AAA Solution - Centralized Authentication

Proposed solution: AAA solution provided by the FortiAuthenticator that includes the use of RADIUS protocol for VPN authentication and network access authentication and TACACS+ protocol for switch/router/firewall administrative access, which is integrated with Active Directory as the source of identity and uses Forti Token MFA for remote and privileged access.

Alternative consideration: Microsoft Network Policy Server (NPS) with Active Directory.

NPS is effectively free with the Windows Server licensing Northbridge already holds, is familiar to general IT staff, and is a perfectly capable RADIUS server, so it was seriously considered on cost grounds. It was rejected because NPS supports RADIUS only and has no

TACACS+ capability. That distinction matters more than it first appears: RADIUS authorizes a session, whereas TACACS+ authorizes and logs individual commands on network devices. Northbridge's device administration problem is precisely that nobody can say who changed what on which switch, and NPS cannot answer that question. Choosing it would mean either leaving device administration on local shared accounts, which is the vulnerability in my Threat 2, or running a second separate TACACS+ system alongside it and doubling the number of platforms a newly formed team has to operate.

Northbridge specific justification: As noted in the scenario, Northbridge does not have an authentication mechanism in place, and each individual device and application has its own user account set locally. In addition, password reuse and password sharing is common amongst the branch office staff. This is not a problem that requires tuning but a problem of missing the identity layer. One platform for both user and device administration will do away with the local user account sprawl at all the branches as well as at the head office, and allow password policy enforcement, MFA and lockout along with per-command accounting in order to catch the intrusion via branch equipment. Choosing the same vendor for the identity platform as well as the two others proposed for the firewall and the VPN will keep the number of management platforms minimal, which is intentional for a new security team.

Secure Network Architecture - Multiple Firewalls, Defined Zones

Proposed solution: A back-to-back dual firewall design. The first firewall, a next-generation firewall, is situated at the perimeter and is responsible for the screening of a DMZ containing the web banking front end, the mobile application gateway, external DNS, and the mail relay. The second firewall, which is an internal next-generation firewall, is placed between the DMZ and the internal estate. This firewall creates a barrier between the core banking server area, a branch area where each of the six branches has its own VLAN, a corporate employee area, a bring your own device (BYOD) area, a guest Wi-Fi internet access only area, an out-of-band management area where the AAA platform and the logging servers reside, and a partner area that terminates the tunnels to the two payment processing partners.

Alternative considered: A single collapsed next-generation firewall with multiple interfaces, enforcing the same zones logically on one device.

The collapsed design would be less expensive and use only one device licensing and training, with modern zone-based policy truly capable of articulating the same rules, so was taken into account because of the size of the organization. However, it was not chosen due to making a single device the internet perimeter and the last barrier to the core banking database, thus making configuration or platform vulnerabilities render all the boundary irrelevant. The second approach to consider was a dual-vendor implementation where different vendors would provide equipment at the perimeter and inside, according to the defense-in-depth argument. However, it also did not work since two vendors make two different models of security policies and require two skills, and since Northbridge has reached a certain level of maturity, a misconfiguration becomes much more likely cause of a problem than platform vulnerability.

Northbridge specific justification: According to the scenario, the network has evolved organically through more than a decade without any explicit segmentation process, and that the systems at the head office, branch offices, guest Wi-Fi, and point-of-service support equipment

all live in the same unsegmented network space. In both of my proposed threat scenarios, the success of those threats hinges solely on that unsegmentation, with the stolen VPN credential from Threat 1 and the rogue device in Threat 2 each being completely benign until the hacker discovers that the core banking environment is right next door. There are two aspects to this network that are particular to Northbridge, rather than good practices in general. Having separate VLANs for each of the branches means that an attack on one branch does not affect a peer branch, thus interrupting the ransomware chain that was reported by the regional industry association. The partner network is provisioned already, prior to the payment processor integration that will occur in the next two quarters, since that integration will extend trust outside of Northbridge's own infrastructure for the first time.

IDS/IPS Solution

Proposed solution: The FortiGuard IPS engine has been implemented in-line on both firewalls, and the more significant implementation is the internal firewall because all the traffic that will travel from east to west between the branch, BYOD, and VPN zones, and the core banking zones should be filtered, as well as a passive Suricata sensor that will reside on the SPAN port in the head office data center whose logs will be sent to the centralized logging platform.

Alternative consideration: Passive Snort or Suricata sensors on SPAN ports at each site, with no in-line component.

A totally passive implementation is cost-free, has a great detection engine, and has no possibility of dropping good traffic, which is important due to the critical dependency of branch-to-head office connectivity. It was not selected as the primary control method since the SPAN port sensor can only monitor the flow, meaning it does not have the ability to prevent it. The threat that necessitates this exercise is the fast-spreading ransomware across the unsegmented network and having a detection system that will trigger an alarm for a team that is not used to working off hours will not halt the spreading process. Northbridge does not have the capability to respond 24/7 that could render detection control effective; thus, the control should be able to act independently. A dedicated standalone IPS appliance was also an option that was declined since at 450 employees across seven locations, the throughput argument does not hold.

Northbridge specific justification: The scenario clearly indicates the lack of any sort of detection or prevention capabilities on the network that will keep the bank blind to both reconnaissance activities as well as active attacks until they start showing some effects. For Northbridge, the decision about choosing the location of inspection is very crucial because both my chosen threats assume that the attacker is already in the network – either on a VPN session in the first case or on a branch switch port in the second case – so that a perimeter IPS system will not even get to know about these threats. The first thing an attacker does after gaining access is to perform a scan on a flat network to find out which hosts are reachable, and by inspecting east-west traffic, Northbridge can make sure that it is the first thing it is going to detect regarding these two threats when they still can be stopped. The passive device is used deliberately along with the in-line system because there is no centralized logging or auditing in the bank.

Member 4 - IT24102328 – Wickrama Edirisooriya A.A.G.

VPN solution for secure remote access

Recommended solution: Palo Alto Networks GlobalProtect SSL/IPSec VPN terminates on a Palo Alto PA-Series next-generation firewall at the head office, per-user accounts for all remote employees, mandatory Multi-Factor Authentication (MFA) using RADIUS and one-time passcodes, and Host Information Profile (HIP) endpoint verification of OS patch level and antivirus status before the tunnel is established, including any external contractors.

Alternative consideration: Fortinet FortiGate SSL-VPN with FortiClient and FortiToken MFA is considered as an alternative. It provided per-user accounts, MFA and endpoint compliance checks all in one platform and would have matched the Fortinet firewall and AAA stack that another member had proposed. It was rejected as it focuses all its security layers on a single vendor. If an exploit was discovered in that vendor's firewall or its VPN or authentication software, Northbridge would have no other second layer of security to fall back on – a big risk for a bank that's barely built its security infrastructure.

Northbridge Specific Justification: Remote access is granted via a single shared VPN account which is rotated amongst remote staff and 2 external contractors; remote staff has no personal accountability and there is no MFA. The scenario also confirms that Northbridge has no rules about work from home and personal devices. GlobalProtect's HIP checks are the only control in the alternatives that tests the condition of connecting device before it's connected to the tunnel, in that case, an unpatched RDP-exploited personal laptop with EternalBlue or unpatched personal laptop containing RDP-exploited software is denied or quarantined, not allowed onto the internal network. This directly diminishes the attack surface on which Threat 1 relies, and helps with a forensic reconstruction, which Northbridge does not yet support for Threat 2.

An AAA solution for centralized authentication

Recommended solution: deploy Aruba ClearPass Policy Manager as a RADIUS server for network authentication and VPN access, and to deploy Aruba ClearPass OnGuard as an endpoint posture assessment tool and MFA (multi-factor authentication) enforcement server, with Active Directory as the identity source.

Alternative consideration: Microsoft Network Policy Server (NPS) + Active Directory. NPS is free (due to the Windows Server licensing Northbridge already had), is well-known to a wide range of IT staff, and is a perfectly capable RADIUS server, which made it a serious contender on a cost basis. It was so because NPS has no TACACS+ capability and only supports RADIUS. Unlike TACACS+, RADIUS authorizes a session and TACACS+ authorizes and logs commands on network devices. When somebody changes something on one of the switches in Northbridge, it is impossible to tell who did what and no one will know what NPS has to answer to in that regard. The selection of it would leave a weakness in Threat 2, namely device administration on local shared accounts, or a second TACACS+ system would be needed in addition.

Northbridge-specific justification: All devices and applications have their own set of users and password sharing and reuse is very prevalent amongst the branch office staff

members. At all six branches and head office the ClearPass eliminates the local-account sprawl, centrally enforces password policy, MFA, and account lockout, and delivers per-command accounting on network devices that directly addresses the lack of an audit trail in Threat 2. ClearPass OnGuard is also capable of endpoint posture checks and can quarantine a device that is not patched or does not have the right AV software; an unpatched branch system can't join the network silently and serve as the first point of entry for the EternalBlue or unpatched RDP exploit path in Threat 1.

A secure network architecture incorporating multiple firewalls and defined zones

Proposed solution: 3-tiered firewall structure – Palo Alto PA-Series next-generation firewalls at perimeter and boundary, and a dedicated industrial firewall in front of the point-of-service and branch support equipment. The design comprises of zones dedicated to Internet, public DMZ (Online banking portal, Mobile app gateway, External DNS and mail relay), core banking zone, database zone, out-of-band management zone (for AAA and logging servers), guest Wi-Fi zone (restricted to Internet), an isolated PoS/OT zone (behind an industrial firewall), one VLAN per branch, a partner zone (tunnels terminated to the two payment processors), and remote VPN user zone.

Alternative consideration: Use a single collapsed next generation fire wall that has multiple interfaces and multiple VLANs. It would be less costly and need only a single device for licensing & training; for the size of the organisation, it was considered. It was rejected, as it would turn one device into the last line of defense in the perimeter of the internet and against the core banking database. If there's a configuration error, or if any platform is vulnerable, on that one device, the entire boundary would be rendered moot, and Northbridge has no platform change-management maturity to support the notion that it can accept that risk.

Northbridge-specific justification: The scenario is that the network has been organically grown and has been used for over 10 years without a formal segmentation strategy, the head office systems are used in the same flat network space and the same goes for the branch systems, guest wi-fi and point-of-sale support equipment. An unpatched branch workstation exploited as in Threat 1 will not be able to move laterally to the core banking zone and a single VLAN per branch means an attack on one branch will not propagate to a peer branch. The PoS/OT zone is deliberately separated from the Internet by a dedicated industrial firewall in front, as is typical of Northbridge's branch environment. Even if a physical connection is made between a rogue device and an unlocked branch cabinet (as in Threat 2), the industrial firewall can still enforce protocol-level restrictions to prevent the rogue device from scanning, ARP-poisoning, or pivoting into the corporate or core banking zone.

An IDS/IPS solution

Recommended solution: Palo Alto Threat Prevention IPS deployed in-line on the perimeter and internal next generation firewalls, with Cisco Secure Network Analytics (Stealthwatch) anomaly detection that is based on flow, using NetFlow and IPFIX from all next generation

firewalls and switches. This is a signature based inline prevention combined with behavioural detection of traffic in both the east-west and north-south directions.

Alternative consideration: Only install passive Snort or Suricata sensors on the SPAN ports without an in-line sensor. Important, since Northbridge requires continuous branch to head office connectivity, it is cost-free, has a great detection engine, and does not drop legitimate traffic. It was not selected as the primary control because a SPAN port sensor can only monitor the flow and does not have the ability to prevent it. This is because the threat—the ransomware in an unsegmented network—is one that is hard to prevent and a detection system that sounds an alarm for a team that is not accustomed to working after hours will not slow the spread. But Northbridge is not able to respond 24 hours a day to make a detection-only control effective, so the control needs to be able to respond on its own.

Northbridge-specific justification: The scenario confirms that there is NO intrusion detection or intrusion prevention anywhere on the network, which means that the bank is unable to see any reconnaissance or active intrusion until there is a visible damage. A perimeter-only IPS would not detect the two threats modeled by this member because they assume that the attacker is already on the inside, via unpatched systems or via physical access to a branch cabinet. In-line IPS sits at the branch-to-core boundary before malicious east-west traffic reaches the core network and can be dropped where it is. Unlike standard logging, which is not possible because Northbridge cannot respond 24/7, in-line IPS can be dropped at the branch-to-core boundary. In addition to IPS capabilities, Stealthwatch includes flow-based anomaly detection, which is able to detect encrypted or new lateral movement – including SMB scanning or anomalies in east-west flows – that signature-based IPS can't. When an attacker actually wires up a rogue device to a branch cabinet, Stealthwatch is already able to see the reconnaissance and scanning activity, before a signature fires, and to give Northbridge the flow records needed to recreate a forensics analysis of the attacker's network footprint.

Important:

Remember

- *Plagiarism is considered as a serious crime against intellectual property in academic environments.*
- *By including the declaration page mentioned below, you abide by the laws of the institute to accept 0 marks for the report, in case you get caught attempting plagiarism.*

Annexure 1

General Formatting

1. Paper size: A4
2. Contents font & size: Times New Roman, size 12
3. Chapter headings/sub headings font & size: Times New Roman Bold, size 12
4. Page numbering:
 - Cover page should not contain any number
 - Declaration page to table of figures page should be numbered using Roman numbers at bottom center of the page
 - Content pages, references page(s) and annexes (if any) should be numbered using Arabic numbers at the bottom center of the page
5. Margins: 1 inch margins on left, right, top and bottom
6. Line spacing: 1 line spacing

Figure Numbering:

1. Each figure should be numbered at bottom center of the figure along with a figure name.
2. Figure number should start with word 'Figure' followed by the 'main chapter number' and 'figure number within the chapter' separated by a 'period sign (.)' and followed by a 'colon (:)'.

For example,

Figure 2.6: XYZ Connector

Declaration Page:

Declaration page should contain the following. Reports that does not contain this declaration 'AS IS' will not be accepted as valid reports and will be awarded 0 marks.

Declaration

I certify that this report does not incorporate without acknowledgement, any material previously submitted for a degree or diploma in any university, and to the best of my knowledge and belief it does not contain any material previously published or written by another person, except where due reference is made in text